



**PERFORMANCE WORK STATEMENT (PWS)
DEPARTMENT OF VETERANS AFFAIRS**

Office of Information & Technology (OIT)

Digital Service Delivery (DSD)

Health Services Portfolio

Healthcare Environment and Logistics Management (HELM)

Supply Chain Management Development Security Operations (SCMDSO) Integration

Date: April 21, 2026

VA-26-00021946

PWS Version Number: 1.0

Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946

Contents

1.0	BACKGROUND.....	5
2.0	APPLICABLE DOCUMENTS.....	6
3.0	SCOPE OF WORK.....	10
3.1	ORDER TYPE.....	11
4.0	PERFORMANCE DETAILS.....	11
4.1	PERFORMANCE PERIOD	11
4.2	PLACE OF PERFORMANCE	11
4.3	TRAVEL.....	12
4.4	LABOR CATEGORY SKILLSET AND CERTIFICATION	12
5.0	SPECIFIC TASKS AND DELIVERABLES	13
5.1	PROJECT MANAGEMENT (FFP)	13
5.1.1	CONTRACTOR PROJECT MANAGEMENT PLAN.....	13
5.1.2	REPORTING REQUIREMENTS	14
5.1.3	PROGRESS REPORTS	15
5.1.4	TECHNICAL KICKOFF MEEETING	15
5.1.5	VA MANDATORY TRAINING.....	15
5.1.6	ONBOARDING / OFFBOARDING.....	16
5.1.6.1	ONBOARDING ACTIVITIES.....	16
5.1.6.2	OFFBOARDING ACTIVITIES.....	17
5.2	HELM PRODUCT LINE MANAGEMENT SUPPORT (FFP)	17
5.2.1	HELM PRODUCT LINE SUPPORT.....	17
5.2.2	INTAKE PROCESS	18
5.2.3	PROGRAM INCREMENT PLANNING.....	20
5.2.4	INNOVATION TREND ANALYSIS AND PLANNING.....	21
5.3	SCRUM TEAM SUPPORT (OPTIONAL TASK 1) (FFP).....	21
5.3.1	MICRO SCRUM TEAM.....	22
5.3.2	SMALL SCRUM TEAM.....	22
5.3.3	MEDIUM SCRUM TEAM	23
5.3.4	LARGE SCRUM TEAM	23
5.4	HIGHLY TECHNICAL SCRUM TEAM support (Optional task 2) (ffp).....	23
5.4.1	MICRO HIGHLY TECHNICAL SCRUM TEAM (OPTIONAL TASK) (FFP)	24
5.4.2	SMALL HIGHLY TECHNICAL SCRUM TEAM	24
5.4.3	MEDIUM HIGHLY TECHNICAL SCRUM TEAM	24
5.4.4	LARGE HIGHLY TECHNICAL SCRUM TEAM.....	25
5.5	SUPPLY CHAIN PRODUCT SUPPORT (teamS) (optional HELM PL PRODUCT/PROJECT).....	25
5.5.1	SOFTWARE DEVELOPMENT LIFECYCLE (SDLC) ACTIVITIES	25
5.5.2	CONFIGURATION MANAGEMENT	26
5.5.3	RISK & ISSUE MANAGEMENT	27
5.5.4	SCHEDULE MANAGEMENT	28
5.5.5	USER EXPERIENCE MANAGEMENT	28
5.5.6	USER RESEARCH.....	29
5.5.7	AGILE REQUIREMENTS ELABORATION.....	29
5.5.8	CONTENT DESIGN	30
5.5.9	PRODUCT TESTING	30

Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946

5.5.9.1	INTEGRATED TESTING ACTIVITIES.....	31
5.5.9.2	TEST PLANNING AND DOCUMENTATION	32
5.5.9.3	DEFECT MANAGEMENT	32
5.5.9.4	REPORTING	32
5.5.9.5	RELEASE READINESS CRITERIA.....	33
5.5.10	PRODUCT ARCHITECTURE	33
5.5.11	DATA MANAGEMENT AND MIGRATION SUPPORT	34
5.5.11.1	DATA TOOLS DEVELOPMENT AND TESTING SUPPORT	35
5.5.11.2	DATA EXTRACTION AND ANALYTICS.....	35
5.5.11.3	DATA MAPPING AND VALIDATION.....	35
5.5.11.4	MIGRATION PLANNING, ENVIRONMENT SUPPORT, AND TESTING	36
5.5.12	TRAINING SUPPORT	36
5.5.13	AI/ML OPTIMIZATION AND PREDICTIVE ANALYTICS	37
5.6	RELEASE SUPPORT (optional HELM PL PRODUCT/PROJECT).....	38
5.6.1	PRERELEASE SUPPORT	38
5.6.2	ASSESSMENT AND AUTHORIZATION (A&A) SUPPORT.....	39
5.6.3	INITIAL OPERATING CAPABILITY (IOC) SUPPORT	40
5.6.4	RELEASE AND DEPLOYMENT SUPPORT.....	40
5.7	POST DEPLOYMENT SUPPORT (optional HELM PL PRODUCT/PROJECT)	42
5.7.1	AFTER BUSINESS HOUR SUPPORT	44
5.8	VALIP SUSTAINMENT SUPPORT (optional HELM PL PRODUCT/PROJECT)	44
5.8.1	VALIP CLOUD ECOSYSTEM DEVELOPMENT AND MANAGEMENT	45
5.8.2	INTEGRATION AND INTEROPERABILITY	46
5.9	BUILD AND DEVELOPMENT (optional HELM PL PRODUCT/PROJECT)	47
5.9.1	SOLUTION ARCHITECTURE PLANNING AND EXECUTION.....	47
5.9.2	BUILD PLANNING.....	48
5.9.3	SPRINT PLANNING	49
5.9.4	SPRINT EXECUTION.....	50
5.10	APPLICATION PERFORMANCE MONITORING AND ALERTING (optional HELM PL PRODUCT/PROJECT).....	51
5.10.1	APPLICATION PERFORMANCE MONITORING (APM).....	51
5.10.2	APPLICATION MONITORING PLAN (AMP)	52
5.10.3	DECOMISSIONING SUPPORT	53
5.10.3.1	ALTERNATE SOLUTIONS FOR DECOMISSIONING SYSTEMS....	53
5.10.3.2	DECOMISSIONING PLAN	54
5.10.3.3	TECHNICAL SUPPORT FOR DECOMISSIONING.....	54
5.11	MIGRATION TO CLOUD ENVIRONMENT & HOSTING SUPPORT (optional HELM PL PRODUCT/PROJECT).....	54
5.11.1	VAEC CLOUD HOSTING	56
5.11.2	EXTERNAL HOSTED APPLICATION	57
5.12	INFRASTRUCTURE AND SECURITY REQUIREMENTS (optional HELM PL PRODUCT/PROJECT).....	57
5.13	ADDITIONAL IMPLEMENTATION SUPPORT (OPTIONAL TASK 3) (T&M)..	58

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

5.13.1	OPTIONAL TASK – HELM SCM DSO SUPPORT SERVICES (T&M)	58
5.14	TRANSITION SUPPORT (OPTIONAL TASK FOUR)	59
6.0	GENERAL REQUIREMENTS	60
6.1	ENTERPRISE AND IT FRAMEWORK	60
6.1.1	VA TECHNICAL REFERENCE MODEL	60
6.1.2	ZERO TRUST – VA CRITICAL SECURITY CONTROLS	60
6.1.3	FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)	60
6.1.4	INTERNET PROTOCOL VERSION 6 (IPv6)	62
6.1.5	TRUSTED INTERNET CONNECTION (TIC)	62
6.1.6	STANDARD COMPUTER CONFIGURATION	62
6.1.7	VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM)	63
6.1.8	PROCESS ASSET LIBRARY (PAL)	63
6.1.9	AUTHORITATIVE DATA SOURCES	64
6.1.10	SOCIAL SECURITY NUMBER (SSN) REDUCTION	65
6.1.11	GENERATIVE ARTIFICIAL INTELLIGENCE REQUIREMENTS	65
6.1.11.1	AI SYSTEM/LLM DEVELOPMENT AND OPERATION DOCUMENTATION REQUIREMENTS	67
6.1.11.2	MONITORING, REPORTING, AND CORRECTIVE ACTION	68
6.1.11.3	AI MODEL UPDATES AND CHANGE DISCLOSURES	68
6.1.12	SOURCE CODE HARMONIZATION AND REUSE IN INFORMATION TECHNOLOGY (SHARE IT Act)	69
6.2	SECURITY AND PRIVACY REQUIREMENTS	69
6.2.1	POSITION/TASK RISK DESIGNATION LEVEL(S)	69
6.2.2	CONTRACTOR PERSONNEL SECURITY REQUIREMENTS	70
6.3	METHOD AND DISTRIBUTION OF DELIVERABLES	72
6.4	PERFORMANCE METRICS	72
6.5	FACILITY/RESOURCE PROVISIONS	73
6.6	GOVERNMENT FURNISHED PROPERTY	75
	ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED	77
	ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/ PRIVACY LANGUAGE	83

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

1.0 BACKGROUND

The Department of Veterans Affairs (VA) Office of Information and Technology (OIT) Product Delivery Services (PDS) delivers integrated digital capabilities that support Veteran care nationwide. Within PDS, the Health Services Portfolio's Healthcare Environment and Logistics Management (HELM) Product Line (PL) implements, modernizes, sustains, standardizes, and streamlines software solutions for supply chain, logistics, expendables, assets, inventory, facilities, prosthetics, and environmental compliance. HELM provides the enterprise capabilities needed to support a unified, efficient, and data driven supply chain and logistics environment across VA. VA does not currently operate with standardized, enterprise-wide supply chain business processes or technical systems. Numerous functional and capability gaps have been identified through Government Accountability Office (GAO) and Office of Inspector General (OIG) audits and internal assessments. VA requires accurate, reliable, and accessible supply chain data to improve ordering, fulfillment, and operational performance. These needs align with VA's Strategic Supply Chain (SC) Prioritization and Digital Modernization Strategy, which emphasize modernizing legacy systems, strengthening cybersecurity and resilience, improving data quality, enhancing user experience for logisticians, and establishing consistent, interoperable processes across VHA, VACO, VBA, and NCA.

VA currently relies on approximately 63 disparate legacy systems across 174 sites, resulting in fragmented operations, limited enterprise visibility, and inefficiencies. Standardization and modernization are required to transform Supply Chain systems into integrated, enterprise-wide system of systems that supports responsive, efficient clinical and nonclinical supply operations.

To meet mission needs, VA requires a full service, standardized, scalable healthcare logistics software solutions with modern supply chain management capabilities. A unified digital environment shall enable lifecycle management efficiencies, data driven decision making, and seamless integration with major initiatives such as the Electronic Health Record Modernization (EHRM) and Financial Management Business Transformation (FMBT) programs. HELM's mission and modernization efforts directly support these enterprise requirements by advancing cloud-based logistics capabilities, modernizing legacy applications, and enabling consistent processes across VA's supply chain functions. In addition to modernization activities, several HELM products require ongoing Operation & Maintenance (O&M) support, enhancements, operation stability, security and Lifecycle support.

HELM is organized into five subproduct lines (SPL): Environmental and Healthcare Management, Healthcare Technology and Asset Management, Expendable Inventory Management, Prosthetics, and Technical Services. Additional products scheduled such as Enterprise Asset Management Computerized Maintenance Management System (EAM CMMS), Enterprise Expendable Inventory Management (EEIM) to be incorporated into the product line over the course of this contract Period of Performance (PoP), see Attachment 1 - HELM Products. Attachment 1 represents both products that

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

HELM provides full Software Development Life Cycle (SDLC) support and ownership, and VHA owned products where HELM provides varying levels of support.

2.0 APPLICABLE DOCUMENTS

In the performance of the tasks associated with this Performance Work Statement, the Contractor shall comply with the following:

1. "Federal Information Security Modernization Act of 2014"
2. Federal Information Processing Standards (FIPS) Publication 140-3, "Security Requirements for Cryptographic Modules", March 22, 2019
3. FIPS Pub 199. "Standards for Security Categorization of Federal Information and Information Systems," February 2004
4. FIPS Pub 200, "Minimum Security Requirements for Federal Information and Information Systems," March 2006
5. FIPS Pub 201-3, "Personal Identity Verification of Federal Employees and Contractors," January 2022
6. 10 U.S.C. § 2224, "Defense Information Assurance Program", as amended
7. 5 U.S.C. § 552a, as amended, "The Privacy Act of 1974"
8. Public Law 109-461 (P.L. 109-461), Veterans Benefits, Health Care, and Information Technology Act of 2006, as amended, Title IX, Information Security Matters
9. 42 U.S.C. § 2000d "Title VI of the Civil Rights Act of 1964", as amended
10. VA Directive 0710, "Personnel Vetting Program," September 8, 2025, <https://www.va.gov/vapubs/index.cfm>
11. VA Handbook 0710, "Personnel Vetting Program," September 8, 2025, <https://www.va.gov/vapubs/index.cfm>
12. VA Directive 6102, "Internet/Intranet Services," August 5, 2019
13. 36 C.F.R. Part 1194 "Information and Communication Technology Standards and Guidelines," as amended
14. Office of Management and Budget (OMB) Circular A-130, "Managing Federal Information as a Strategic Resource," July 28, 2016
15. 32 C.F.R. Part 199, "Civilian Health and Medical Program of the Uniformed Services (CHAMPUS)", as amended
16. NIST SP 800-66 Rev. 2, "Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide," February 2024
17. 45 C.F.R Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information ("Privacy Rule"); and 45 C.F.R. Parts 160 and 164, Subparts A and C, the Security Standard ("Security Rule"); as amended
18. Sections 504 and 508 of the Rehabilitation Act (29 U.S.C. § 794d), as amended
19. Homeland Security Presidential Directive (12) (HSPD-12), August 27, 2004
20. VA Directive 6500, "VA Cybersecurity Program," February 24, 2021 (see VA NOTICE 24-18, dated September 27, 2024, "Update to VA Directive 6500 Cybersecurity Program", and VA Notice 25-07, dated 3/18/25, "Amending VA Directive 6500 to incorporate M-24-15")

Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946

21. VA Handbook 6500, "Risk Management Framework for VA Information Systems VA Information Security Program," February 24, 2021 (see VA Notice 25-01, dated October 15, 2024, "Update to VA Handbook 6500 Risk Management Framework for VA Information Systems VA Information Security Program", and VA Notice 25-06, dated 3/18/25, "Amending VA Directive 6500 to incorporate M-24-15", VA Notice 25-16, dated September 15, 2025, "Amending VA Handbook 6500 to Replace Enterprise Mission Assurance Support Services Tool With Office of Information Technology Governance Risk Compliance Tool, and VA Notice 25-17, dated September 22, 2025, "Rescission Of Office Of Information Security (OIS) Deputy Assistant Secretary (DAS) Memorandum – Requirements of Proper Plan of Action and Milestones (POA&M) Completion)
22. VA Handbook 6500.2, "Management of Breaches Involving Sensitive Personal Information (SPI)," June 30, 2023
23. VA Handbook 6500.6, "Contract Security," March 12, 2010 (see VA Notice 24-12, dated April 22, 2024, "Update to VA Handbook 6500.6, Contract Security, Appendix C VA Information and Information System Security/Privacy Language For Inclusion Into Contracts, As Appropriate")
24. VA Handbook 6500.8, "Information System Contingency Planning," March 25, 2025
25. VA Handbook 6500.10, "Mobile Device Security Policy," February 15, 2018 (see VA NOTICE 25-10, dated June 9, 2025, "Use of Personally Owned Mobile Devices Policy Amendment of Department of Veterans Affairs Handbook 6500.10", and VA Notice 25-15, dated August 22, 2025, "Update to VA Handbook 6500.10 Mobile Device Security Policy")
26. VA Handbook 6500.11, "VA Firewall Configuration," August 22, 2017
27. OIT Process Asset Library (PAL), [OIT Process Asset Library](#).
28. One-VA Technical Reference Model (TRM) (reference at <https://www.va.gov/trm/TRMHomePage.aspx>)
29. VA Directive 6508, "Implementation of Privacy Threshold Analysis and Privacy Impact Assessment," October 15, 2014
30. VA Directive 6510, "VA Identity, Credential and Access Management," September 3, 2024
31. VA Handbook 6510, "VA Identity, Credential and Access Management," September 27, 2024
32. VA Directive and Handbook 6513, "Secure External Connections," October 12, 2017
33. VA Directive 6300, "Records and Information Management," September 21, 2018
34. VA Handbook, 6300.1, "Records Management Procedures," March 24, 2010
35. NIST SP 800-37 Rev 2, "Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy," December 2018
36. NIST SP 800-53 Rev. 5, "Security and Privacy Controls for Federal Information Systems and Organizations," September 23, 2020 (includes updates as of 12/10/2020)
37. VA Directive 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," October 26, 2015

Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946

38. VA Handbook 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," March 24, 2014
39. OMB Memorandum 05-24, "Implementation of Homeland Security Presidential Directive (HSPD) 12 – Policy for a Common Identification Standard for Federal Employees and Contractors," August 5, 2005
40. OMB Memorandum M-19-17, "Enabling Mission Delivery Through Improved Identity, Credential, and Access Management," May 21, 2019
41. OMB Memorandum, "Guidance for Homeland Security Presidential Directive (HSPD) 12 Implementation," May 23, 2008
42. Federal Identity, Credential, and Access Management (FICAM) Architecture, June 30, 2023 ([FICAM Architecture \(idmanagement.gov\)](https://www.ficam.gov/))
43. NIST SP 800-116 Rev 1, "Guidelines for the Use of Personal Identity Verification (PIV) Credentials in Facility Access," June 2018
44. NIST SP 800-63-Rev 4, 800-63A-4, 800-63B-4, 800-63C-4, "Digital Identity Guidelines," August 1, 2025
45. NIST SP 800-157, "Guidelines for Derived PIV Credentials," December 2014
46. VA Memorandum, VAIQ #7100147, "Continued Implementation of Homeland Security Presidential Directive 12 (HSPD-12)," April 29, 2011 (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>)
47. IAM Identity Management Business Requirements Guidance document, May 2013, (reference Enterprise Architecture Section, PIV/IAM (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>))
48. VA Memorandum "Personal Identity Verification (PIV) Logical Access Policy Clarification," July 17, 2019, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>
49. Trusted Internet Connections (TIC) 3.0 Core Guidance Documents, <https://www.cisa.gov/publication/tic-30-core-guidance-documents>
50. OMB Memorandum M-19-26, "Update to the Trusted Internet Connections (TIC) Initiative," September 12, 2019
51. OMB Memorandum M-08-23, "Securing the Federal Government's Domain Name System Infrastructure," August 22, 2008
52. Sections 524 and 525 of the Energy Independence and Security Act of 2007, (P.L. 110–140), December 19, 2007
53. Section 104 of the Energy Policy Act of 2005, (P.L. 109–58), August 8, 2005
54. Executive Order 13221, "Energy-Efficient Standby Power Devices," August 2, 2001
55. VA Directive 0057, "VA Environmental Management Program," October 25, 2022
56. Executive Order 14148, "Initial Rescissions of Harmful Executive Orders and Actions," dated January 20, 2025
57. Office of Information Security (OIS) VAIQ #7424808 Memorandum, "Remote Access," January 15, 2014, <https://www.voa.va.gov/DocumentListPublic.aspx?NodeID=28>
58. Clinger-Cohen Act of 1996, 40 U.S.C. §11101 and §11103
59. "Veteran Focused Integration Process (VIP) Guide 4.0," March 2021, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371>

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

60. VA Memorandum "Proper Use of Email and Other Messaging Services," January 2, 2018, <https://www.voa.va.gov/DocumentListPublic.aspx?NodeID=28>
61. "Product Line Management Transformation Playbook" version 3.1, August 2023, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>
62. NIST SP 500-267B Revision 1, "USGv6 Profile," November 2020
63. OMB Memorandum M-21-07, "Completing the Transition to Internet Protocol Version 6 (IPv6)," November 19, 2020
64. Social Security Number (SSN) Fraud Prevention Act of 2017
65. Section 240 of the Consolidated Appropriations Act (CAA) 2018, March 23, 2018
66. C.F.R Title 15 Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain", as amended
67. Executive Order 14028, "Executive Order on Improving the Nation's Cybersecurity," May 12, 2021, <https://bidenwhitehouse.archives.gov/briefing-room/presidential-actions/2025/01/16/executive-order-on-strengthening-and-promoting-innovation-in-the-nations-cybersecurity/>
68. OMB Memorandum M-22-09, "Moving the U.S. Government Toward Zero Trust Cybersecurity Principles", January 26, 2022, <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>.
69. NIST SP 800-52 Revision 2, "Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations
70. [OMB M-26-05, "Adopting a Risk-based Approach to Software and Hardware Security," January 23, 2026](#)
71. OMB M-21-31, "Improving the Federal Government's Investigative and Remediation Capabilities Related to Cybersecurity Incidents," August 27, 2021
72. NIST SP 800-88 Revision 1 "Guidelines for Media Sanitization," December 2014
73. CISA Binding Operational Directive (BOD) 19-02: "Vulnerability Remediation Requirements of Internet-Accessible Systems," April 29, 2019, [BOD 19-02: Vulnerability Remediation Requirements for Internet-Accessible Systems | CISA](#)
74. CISA BOD 22-01: "Reducing the Significant Risk of Known Exploited Vulnerabilities," November 3, 2021, [BOD 22-01: Reducing the Significant Risk of Known Exploited Vulnerabilities | CISA](#)
75. CISA BOD 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks." Cybersecurity & Infrastructure Security Agency (CISA), [BOD 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks | CISA](#)
76. VA Directive 6550, Pre-Procurement Assessment and Implementation of Medical Devices/Systems, June 03, 2019
77. VA Memorandum, "VA Security Controls," January 17, 2025, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>
78. E.O. 13960, "Promoting the Use of Trustworthy Artificial Intelligence in the Federal Government," December 3, 2020
79. E.O. 14319, "Preventing Woke AI in the Federal Government," July 23, 2025
80. OMB Memorandum M-25-21, "Accelerating Federal Use of AI through Innovation, Governance, and Public Trust," April 3, 2025
81. OMB Memorandum M-25-22, "Driving Efficient Acquisition of Artificial Intelligence in Government," April 3, 2025

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- 82. OMB Memorandum M-26-04, "Increasing Public Trust in Artificial Intelligence (AI) Through Unbiased AI Principles," December 11, 2025
- 83. VA Enterprise Cloud Technical Reference Guide, Version 2.0, November 10, 2022
- 84. Attachment (1) HELM Products
- 85. Attachment (2) TBD
- 86. Agile Lifecycle Management Library [alm-library.aspx](#)

3.0 SCOPE OF WORK

This scope applies to existing HELM IT products and any new products introduced during the period of performance. The Government shall provide necessary requirements, system access, and stakeholder coordination. All work shall comply with applicable VA security, privacy, and quality standards and shall align with OIT HELM PL's mission to modernize, secure, streamline, and sustain VA supply chain and logistics capabilities. The Contractor shall provide comprehensive technical, functional, and lifecycle support for existing legacy and future HELM PL products, and new systems incorporated into the product line, in alignment with VA's enterprise digital modernization, cybersecurity, and supply chain transformation strategies. This support shall enable VA's strategic objectives to modernize platforms, standardize, enhance interoperability, strengthen cybersecurity posture, improve supply chain visibility, and deliver resilient, and decommission products.

The scope of work includes full SDLC services; O&M; cybersecurity and regulatory compliance; enterprise deployment; incremental enhancements; implementation and integration support; interface development; platform management; training, Cloud Migration and Hosting services consistent with VA Enterprise Cloud (VAEC) standards; and modernization activities supporting Asset Management, Inventory Management, Prosthetics, and all HELM PL managed solutions.

The Contractor shall apply advanced DevSecOps and engineering capabilities aligned with VA's Zero Trust Architecture Strategy, VA Digital Modernization Strategy, and supply chain modernization objectives. Required activities include secure software development, Continuous Integration and Continuous Delivery (CI/CD) automation, pipeline optimization, continuous monitoring, security assessment and authorization support, configuration and release management, architecture and interoperability analysis, training, data validation and analytics, supply chain risk assessment, and development of technical roadmaps and recommendations that advance VA's enterprise modernization goals.

The Contractor shall also provide program management, technical governance, intake and prioritization support, business process analysis, Risk Management Framework activities, Agile delivery management, and required documentation to ensure secure, efficient, and compliant delivery of HELM capabilities. All services shall adhere to VA cybersecurity, privacy, Section 508, and quality standards and shall integrate with VA enterprise platforms and shared services.

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

3.1 ORDER TYPE

The effort shall be proposed as a hybrid Firm-Fixed Price (FFP) Base with Time and Materials (T&M) optional tasks and a Cost Reimbursable Travel Line.

4.0 PERFORMANCE DETAILS

4.1 PERFORMANCE PERIOD

The PoP shall be one 12-month base period with four 12-month option periods and four optional tasks, if exercised. The overall PoP shall not exceed 60 months.

Any work at the Government site shall not take place on Federal holidays or weekends unless directed by the Contracting Officer (CO). (If required, the CO or Contracting Officer's Representative (COR) or may direct the Contractor to work during holidays and weekends).

There are 11 Federal holidays set by law (USC Title 5 Section 6103) that VA follows:

Under current definitions, five are set by date:

New Year's Day	January 1
Juneteenth	June 19
Independence Day	July 4
Veterans Day	November 11
Christmas Day	December 25

If any of the above falls on a Saturday, then Friday shall be observed as a holiday. Similarly, if one falls on a Sunday, then Monday shall be observed as a holiday.

The other six are set by a day of the week and month:

Martin Luther King's Birthday	Third Monday in January
Washington's Birthday	Third Monday in February
Memorial Day	Last Monday in May
Labor Day	First Monday in September
Columbus Day	Second Monday in October
Thanksgiving	Fourth Thursday in November

4.2 PLACE OF PERFORMANCE

Tasks under this PWS shall be performed at Contractor facilities. The Contractor shall identify the Contractors place of performance in their proposal submission. Work may be performed at remote locations with prior concurrence from the COR and Alternate Contracting Representative (ACOR)

When travel is required, work at the Government site may be required to take place on holidays, or weekends or after business hours and shall be directed by CO or the

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

COR/ACOR. Travel to a Government facility needed to perform the services doesn't change the Place of Performance to the Government Site.

4.3 TRAVEL

The Government encourages the Contractor to maximize its use of teleconferencing and video conferencing for meetings.

The Government anticipates travel to perform the tasks associated with the effort, as well as to attend program-related meetings or conferences throughout the PoP.

Travel and per diem shall be in accordance with the Federal Travel Regulations (FTR) and require advanced concurrence by the COR. The Contractor shall provide cost estimates with each travel request. Each Contractor invoice must include copies of all receipts that support the travel costs claimed in the invoice. Local travel within a 50-mile radius from the Contractor's normal duty location is considered the cost of doing business and shall not be reimbursed. This includes travel, subsistence, and associated labor charges for travel time. Travel performed for personal convenience and daily travel to and from work at the Contractor's facility shall not be reimbursed. Travel, subsistence, and associated labor charges for travel time for travel beyond a 50-mile radius of the Contractor's facility are authorized on a case-by-case basis and must be pre-approved by the COR.

The total number of trips in support of this effort for each 12-month PoP is 12 trips, with 2 people traveling for an average of 8 days per trip.

Anticipated travel can be all CONUS VA Facility locations, and are not limited to the following:

1. Washington, DC
2. Austin, TX
3. Denver (DALC)
4. Florida (Orlando, Bay Pines)

4.4 LABOR CATEGORY SKILLSET AND CERTIFICATION

The contractor shall ensure all personnel assigned to support this requirement meet the applicable Labor Category (LCAT) levels, qualifications, and certifications. The Contractor shall provide resources with a blend of specific expertise and experience in Scaled Agile Framework (SAFe) Agile, Product Management, DevSecOps, engineering, and Data Migration. The Contractor shall adhere to industry standards and requirements referenced in Attachment 2 Labor Category Skillset in filling all positions. The Contractor shall provide cross-functional SAFe resources for the development of enhancements to the HELM products and underlying infrastructure in alignment with VA policies and procedures. The Contractor shall also provide key personnel contractors that are considered/certified Supply Chain Technical Expertise.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

5.0 SPECIFIC TASKS AND DELIVERABLES

The Contractor shall perform the following tasks and provide the specific deliverables described below for each product/project initiated within the performance period stated in this PWS.

The Contractor and/or its subcontractors shall be required, as part of performance under this Task Order, to work with other Government Contractors. In performance of this TO the Contractor shall provide full cooperation with all contractors working for and on behalf of the VA. The Contractor is not authorized to provide guidance, direction, and /or approval of any Contractor's work activities, work products, or deliverables; VA shall provide all directions and/or approval.

Upon award, the COR shall establish initial contact between the Contractor and other Contractors. All interested parties shall participate as applicable. Nondisclosure forms between VA and Contractors shall be executed as appropriate.

The Contractor shall utilize the Agile framework for product management to deliver iteratively & incrementally which regularly produces high quality results in a cost effective, timely, and highly collaborative.

The contractor shall utilize VA Technical Reference Model (TRM) compliant tools in performance of Agile Product Management, test results, scenarios, and results for each product.

The Contractor shall adhere to VA policies by ensuring compliance with DevSecOps practices, implementing Agile methodologies, and supporting other OIT strategic initiatives. To achieve this, the Contractor shall provide a team of subject matter experts (SMEs) to facilitate integration and oversight of capabilities at both the product line and product/solution levels, working collaboratively with stakeholders and partners.

VA shall follow an intake process outlined in PWS Section 5.2.2 when new products/applications/systems require support services from the contract.

5.1 PROJECT MANAGEMENT (FFP)

5.1.1 CONTRACTOR PROJECT MANAGEMENT PLAN

The Contractor shall deliver a Contractor Project Management Plan (CPMP) that lays out the Contractor's approach, timeline, and tools to be used in execution of the contract. The CPMP should take the form of both a narrative and graphic format that displays the schedule, milestones, risks, and resource support. The CPMP shall also include how the Contractor shall coordinate and execute planned, routine, and ad hoc data collection reporting requests as identified within the PWS. The initial baseline CPMP shall be concurred upon and updated in accordance with Section B of the contract. The Contractor shall update and maintain the VA Product Manager (PM)/COR/ACOR approved CPMP throughout the PoP. The Contractor shall provide

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

contractor functional organization chart to ensure contractor leads along with SMEs are clearly delineated.

Deliverable:

- A. Contractor Project Management Plan

5.1.2 REPORTING REQUIREMENTS

The Contractor shall use the VA's implementation of the Jira, GitHub or other VA approved toolset to provide a single Agile project/product lifecycle management tool to track execution details. The VA approved toolset Project/Product Data and Artifact Repository shall be used to provide a single authoritative project and product data and artifact repository. All OIT HELM project data and artifacts shall be required to be managed in this data and artifact repository daily. All checked out artifacts shall be checked back in daily and any data updated daily. VA approved toolset synchronizes all changed information immediately for all team members to access work proficiently without the concern of working on aged information.

The Contractor shall utilize the VA approved toolset to:

- a. Input and manage scheduled project/product sprints and backlog
- b. Input and manage project/product Agile requirements
- c. Input and manage project/product risks and issues
- d. Input and manage project/product configurations and changes
- e. Input and manage project/product test plans and execution
- f. Input and manage project/product planning and engineering documentation
- g. Input and manage project/product user guides and training materials
- h. Input and manage linkages to correlate requirements to change orders to configurable items to risks, impediments, and issues to test cases and test results to show full traceability.
- i. Input and manage linkages to correlate requirements to change orders to configurable items to risks, impediments, and issues to test cases and test results to show full traceability.
- j. Input and manage Enterprise-wide implementation
- k. Input and manage integration with interfaces

The Contractor shall show all Agile requirements, changes, tests performed and test results in the VA approved toolset to show evidence of code coverage and test coverage of all the requirements specified. This expectation shall allow VA to have high confidence in a fully documented, requirements traceability matrix, as evidenced by data in the tools. The Contractor shall track for each product. The Contractor shall support the VA COR in the creation and management of a SharePoint based deliverable library and associated approval workflow. The Contractor shall provide Monthly Deliverable Schedule and Consolidated Performance Report. Format and details will be coordinated with COR and Contractor.

Deliverables:

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- A. Monthly Deliverable Schedule
- B. Consolidated Performance Report

5.1.3 PROGRESS REPORTS

The Contractor shall provide the COR with Monthly Progress Reports in electronic form in Microsoft Word and Project formats and stored in shared repository such as a Teams Channel. The report shall include detailed instructions/explanations for each required data element, to ensure that data is accurate and consistent. These reports shall reflect data as of the last day of the preceding Month.

The Monthly Progress Reports shall cover all work completed during the reporting period and work planned for the subsequent reporting period. The report shall also identify any problems that arose and provide a description of how the problems were resolved. If problems have not been completely resolved, the Contractor shall provide an explanation including their plan and timeframe for resolving the issue. The report shall also include an itemized list of all Information and Communication Technology (ICT) deliverables and their current Section 508 conformance status. The Contractor shall monitor performance against the CPMP and report any deviations. It is expected that the Contractor shall keep in communication with VA accordingly so that issues that arise are transparent to both parties to prevent escalation of outstanding issues.

Deliverable:

- A. Monthly Progress Report

5.1.4 TECHNICAL KICKOFF MEEETING

A technical kickoff meeting shall be held within 10 days after award. The Contractor shall coordinate the date, time, and location (can be virtual) with the CO, the VA PM, the Contract Specialist (CS), and the COR/ACOR. The Contractor shall provide a draft agenda to the CO and VA PM at least five calendar days prior to the meeting. Upon Government approval of the final agenda, the Contractor shall distribute to all meeting attendees. During the kickoff-meeting, the Contractor shall present, for review and approval by the Government, the details of the intended approach, work plan, and project schedule for each effort via a Microsoft Office PowerPoint presentation. At the conclusion of the meeting, the Contractor shall update the presentation with a final slide entitled "Summary Report" which shall include notes on any major issues, agreements, or disagreements discussed during the kickoff meeting. The Contractor shall distribute the updated presentation and meeting minutes to the CO, COR/ACOR and all attendees within three calendar days after the meeting.

Deliverable:

- A. Summary Report

5.1.5 VA MANDATORY TRAINING

All resources are required to have access to the VA network and shall complete all the required VA Talent Management System (TMS) training courses within three business days of submitting an onboarding package. The Contractor shall work with its

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

respective onboarding point of contact and COR/ACOR, to obtain access to TMS to complete the mandatory training courses.

As an action under the Continuous Readiness in Information Security Program, VA's Assistant Secretary for Information and Technology issued a memorandum requiring all VA government and contract staff to complete information security awareness and applicable role-based training. The Contractor shall ensure Training completion and track TMS Training Certificates for VA Privacy and Information Security Awareness, Rules of Behavior, Health Insurance Portability and Accountability Act (HIPAA). If elevated privileges are required Role-Based training shall be identified for completion prior to gaining additional access. The Contractor shall provide and update the master onboarding tracking document of TMS training status.

Deliverable:

- A. Master Onboarding tracking document of TMS training status with updates and TMS Training Certificates of Completion

5.1.6 ONBOARDING / OFFBOARDING

The Contractor shall support the onboarding and offboarding of its staff. The Contractor shall provide a Contract lead to support onboarding and offboarding actions in the IAM Portal. The Contractor shall provide a Weekly Onboarding/Offboarding Status Report as described in sections 5.1.6.1 and 5.1.6.2. The format for the weekly onboarding and offboarding status reports shall be developed collaboratively and approved by the COR/ACOR and the Contractor which shall be saved with all other deliverables.

5.1.6.1 ONBOARDING ACTIVITIES

Onboarding includes steps to obtain a VA PIV card, network and email account, complete training, initiate background investigations, and obtain Government Furnished Equipment (GFE). In addition, the Contractor shall identify individuals which may require elevated privileges to the necessary development and test environments for the various systems to be developed or enhanced.

A single Contractor Onboarding point of contact (POC) and back up POC shall be designated by the Contractor that tracks the onboarding status of all Contractor personnel. The Contractor Onboarding POCs shall be responsible for accurate and timely submission of all required VA onboarding paperwork to the VA COR/ACOR or applicable systems used for onboarding. The Contractor shall be responsible for tracking the status of all its staff's onboarding activities to include the names of all personnel engaged on the task, commercial email address, phone numbers, immediate contract supervisor, onboarding milestone dates, and their initial training date for VA Privacy and Information Security training. The Contractor shall provide an onboarding status in the Weekly Onboarding/Offboarding Status Report for review by the COR/ACOR, VA PM or Government designee. The report shall include:

- Current onboarding status for all personnel.
- Pending onboarding actions.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- Estimated completion dates for outstanding steps.
- Issues or delays impacting onboarding timelines.

The Contractor shall maintain a comprehensive onboarding status tracker that includes:

- Names of all personnel engaged on the task.
- Commercial email address and phone number.
- Immediate contract CTR supervisor.
- Onboarding milestone dates.
- Initial VA Privacy and Information Security training date.
- Percentage of support of resource allocation to what specific product

5.1.6.2 OFFBOARDING ACTIVITIES

The Contractor shall ensure timely offboarding of personnel, including:

- Return of GFE.
- Revocation of elevated privileges.
- Deactivation of network and email accounts.
- Notification to COR/ACOR of personnel departure.

The Contractor shall provide an offboarding status in the Weekly Onboarding/Offboarding Status Report to the COR/ACOR, VA PM, or Government designee, detailing the status of all offboarding activities.

Deliverable:

- A. Weekly Onboarding/Offboarding Status Report

5.2 HELM PRODUCT LINE MANAGEMENT SUPPORT (FFP)

5.2.1 HELM PRODUCT LINE SUPPORT

The Contractor shall holistically advance the systems engineering maturity of the HELM PL by ensuring compliance with DevSecOps practices, implementing Agile methodologies, and supporting VA's Strategic Supply Chain Prioritization and Digital Modernization Strategy. To achieve this, the Contractor shall provide a qualified team of SMEs to facilitate the integration and oversight of capabilities & practices at both the product line and value stream levels, working collaboratively with stakeholders and partners. The Contractor shall support development of HELM PL briefing slides to include monthly Program Management Reviews (PMR) and Program Increment (PI) Planning committed and uncommitted objectives. The Contractor shall provide cross-functional SAFe resources to include SC Technical Expertise for the development of enhancements to the HELM products and underlying infrastructure in alignment with VA policies and procedures.

The Contractor shall:

- Track, process and manage Authority to Operate (ATO) activities for PL by working with each product and SMEs to ensure compliance.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- Provide technical leads/SAFE Roles for PL management for Cyber Security, Solution, Architect/Engineer Architecture, Testing, Technical Lead, Overarching Program Lead, DevSecOps Engineer/Security Specialist
- Assist in defining new application implementation requirements, to include the generation of Epics and translation to Features and User Stories which make up the Product Roadmap and Product Increment Plans while mitigating dependencies between them.
- Consolidate requirements or sequencing to generate product line efficiencies
- Understand future state requirements for the successful implementation of new applications in VA and identify impacts to legacy or dependent systems.
- Provide guidance on dependencies between implementation requirements within and outside the product to reduce risk as new capabilities are introduced and current systems are retired.
- Identify and analyze the systems targeted for integration and the design and technologies needed to implement them.
- Assist with database solutions and designs for data migrations for implementations at VA sites.
- Provide product line analyses of risks and issues to identify trends and possible opportunities for responses and mitigations.
- Understand current and future-state data flows, networking, cybersecurity, and infrastructure requirements.
- Testing, training, sustainment

5.2.2 INTAKE PROCESS

HELM PL requires a standardized, repeatable, and transparent intake process to manage Government provided requirements for existing products, ongoing work, and any new capabilities introduced during the PoP. The Contractor shall partner with the Government to mature, operate, and continuously improve the existing HELM intake process, ensuring all requests are evaluated consistently and accurately.

The Contractor shall not create a new custom-made intake application or standalone web portal. Instead, the Contractor shall use and enhance VA approved platforms (e.g., Jira, SharePoint, Confluence, Power Apps/Automate, or other approved tools) to support intake activities, workflow routing, estimation, documentation, and reporting. Within the first 60 days of the Base Period of PoP, the Contractor shall implement the following Intake Process components:

Centralized Intake Workflow

- Establish a single, unified intake workflow for HELM PL requirements—both new and existing.
- Receive, capture, and track all intake requests using VA approved tools.
- Ensure all requests remain visible to HELM PL leadership, COR/ACOR, VA PMs, product owners, and appropriate VA stakeholders.
- Coordinate with requestors to clarify scope, dependencies, constraints, and priority factors.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

Requirements Analysis & Level of Effort (LOE)

- Analyze each request to determine estimated Level of Effort (LOE), required skill sets, potential scrum team sizing, risk factors, and estimated timeline.
- Conduct interviews, workshops, or follow up sessions with VA requestors and stakeholders, as needed.
- Document assumptions, dependencies, and constraints associated with each estimate.
- Provide standardized LOE outputs to support HELM PL governance and prioritization.

Technical Maturity & DevSecOps Readiness Assessments

- Perform a DevSecOps maturity assessment to document applicable processes, compliance gaps, and technical readiness.
- Conduct high-level architectural assessments to identify reuse opportunities, alignment with Enterprise Architecture, and compatibility with Product Line standards.
- Identify potential impacts to ATO, security posture, and environments.

Architecture Repository & Reuse Library

- Establish and maintain a HELM Architecture Repository within VA approved tools.
- Store vetted design patterns, reusable components, solution templates, and interface patterns.
- Ensure intake analysis includes review of existing patterns to encourage reuse, reduce duplication, and increase technical consistency.

Intake Workflows, SOPs, and Documentation

- Develop and maintain Intake Standard Operating Procedures (SOPs), including required data elements, routing logic, approval steps, timelines, and artifacts.
- Ensure SOPs reflect the actual tools and processes used by HELM PL teams.
- Provide updates to SOPs with each Option Period or as directed by HELM governance.

Requirements Analysis Proposal (RAP)

For each intake request, the Contractor shall develop a RAP for each Option Period, Optional Task and any new requirements that includes:

- Scope, high level objectives, and functional/nonfunctional requirements.
- Estimated LOE, required skill sets, and recommended scrum team composition.
- Expected labor mix and a burndown plan illustrating resource utilization across the Period of Performance.
- High level schedule, milestones, and major dependencies.
- Identified risks, impediments, and mitigation recommendations.
- Required deliverables and applicable HELM PL processes.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

The Contractor shall document and manage all agreed upon deviations from the RAP—resulting from Agile development adjustments, changes in Government priorities, or unforeseen barriers. All changes must be reviewed and approved by HELM PL Leadership and the COR/ACOR.

Integration with HELM Governance

- Ensure intake results (LOE estimates, RAPs, architectural considerations, risk summaries) are formatted to support HELM PL governance and prioritization processes.
- Support monthly and quarterly governance reviews by providing updated backlog statistics, intake disposition, and forecasts.
- Provide Monthly Backlog Report, showing intake volume, disposition, LOE summaries, and aging analysis.
- Intake Dashboard within VA approved tools, updated weekly, reflecting real-time status.

Deliverables

- A. Intake Analysis and Process Guide (SOPs, workflows, forms, estimation model, architecture reuse guidance)
- B. Requirements Analysis Proposal (RAP) for each intake item
- C. Monthly Backlog Report
- D. HELM Product Team Request Intake Tool/Workspace (within existing VA approved systems)

5.2.3 PROGRAM INCREMENT PLANNING

The Contractor shall support and deliver HELM PI Quarterly Planning activities to ensure alignment of product development objectives with VA strategic priorities. PI Planning shall be conducted in accordance with SAFe principles and HELM governance standards.

The Contractor shall:

- Facilitate and participate in HELM PI Planning sessions on a quarterly basis.
- Prepare and deliver all required planning artifacts, including PI Planning Agenda, Feature and Capability Backlogs aligned to VA priorities, Capacity Planning for HELM teams and resources, Dependency Identification and Resolution Plans across teams and programs, and Risk Assessment and Mitigation Strategies documented in a PI Risk Register.
- Coordinate with VA stakeholders to ensure all backlogs (initiatives, epics and stories) are prepared and prioritized and organized into Pre-Read Materials demonstrating that PL/SPL and Architecture visions are aligned, and SWOT analysis are completed prior to planning sessions and prepare PI Planning Summary Report and Objectives.
- Engage with other contractor teams and enterprise stakeholders during PI Planning to ensure shared understanding of dependencies, promote

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

collaboration, and support efficient, non-duplicative execution of product development activities.

- Provide logistical and technical support for PI Planning events (virtual or in-person), including scheduling, tools setup (e.g., Jira, Rally, Mural), and facilitation.
- Post-PI Planning provide an updated HELM PL Program Backlog and Roadmap and provide incremental improvement opportunities for each PI iteration to mature the Product Line PI Planning over time.
- Coordinate with VA Stakeholder to ensure PI Planning Objectives statuses are tracked in monthly HELM PL PMR briefings.

Deliverables:

- A. PI Planning Agenda and Pre-Read Materials (10 Business days prior to PI Planning session)
- B. PI Planning Summary Report, Objectives (5 Business days prior to PI Planning session)
- C. Updated HELM PL Program Backlog and Roadmap: (Delivered 10 Business days after PI Event)
- D. Provide PI Objective status in monthly HELM PL PMR briefing

5.2.4 INNOVATION TREND ANALYSIS AND PLANNING

The Contractor shall support innovation and modernization efforts by identifying and analyzing emerging technologies and industry trends. The Contractor shall:

- Partner with HELM PL leadership to create baseline metrics and a roadmap structure for digital modernization strategies and to improve modern application architectures.
- Advise HELM PL of AI-driven analytics tools to identify performance bottlenecks and provide actionable insights, verified by subject matter experts, on emerging technologies that can improve system performance, enhance automation, and ensure cost efficiency.
- When requested, provide recommendations on emerging technologies assessing their potential impact on performance, automation, and operational efficiency.
- In cooperation with product managers and business stakeholders, identify realistic potential use cases for emerging technologies within supply chain.
- The Contractor shall advise software obsolescence planning for technical refreshes per Technical Reference Model (TRM) and Digital Transformation Center (DTC).

5.3 SCRUM TEAM SUPPORT (OPTIONAL TASK 1) (FFP)

The VA may exercise Scrum team(s) to support HELM PL products and projects with the continuous delivery pipelines as described in PWS sections 5.5 through 5.12. Each exercise may encompass more than one product or project area.

The Contractor shall provide Agile Scrum Teams to support VA Products delivery, including development, testing, integration, data activities, configuration, training,

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

sustainment, and modernization. These teams shall follow SAFe Agile, DevSecOps, and HELM PL governance practices and shall meet or exceed maturity expectations for iterative delivery.

These teams shall provide comprehensive end-to-end support across the SDLC which may include:

- Backlog refinement, elaboration, and decomposition into Features and User Stories
- Sprint Planning, execution, reviews, and retrospectives
- Building, testing, and delivering working software increments
- Supporting DevSecOps pipelines and automation
- Integrating with dependent solutions and enterprise services
- Providing Tier II/III troubleshooting and sustainment support
- Supporting PI Planning and Product Line roadmap execution
- Ensuring delivery of high-quality, traceable, and testable work products
- Enabling accurate measurement of business value, throughput, and delivery efficiency
- Operations and Maintenance (O&M) sustainment services
- Technical Support

Scrum Team Type and Sizes:

Scrum Teams shall be activated only when exercised by the Government via the established HELM Intake Process and COR approval. A Full Time Equivalent (FTE) is defined as 160 hours of contract work per month. All team types follow the same activation rules, reporting requirements, and SAFe compliance. The specific scope of functionality to be delivered for each build in the optional task shall be determined through requirements submitted through Intake Process. Teams shall be priced for a monthly increment with PoPs ranging from one to twelve months. Each Team exercised shall not exceed 12 months. HELM PMs prior to start of a build cycle when applicable shall approve based on current business priorities.

5.3.1 MICRO SCRUM TEAM

The Contractor shall provide an additional scrum team consisting of up to 2-3 resources comprised of the appropriate technical skill sets to support multiple builds throughout each PoP. Recommended for focused enhancements, technical tasks, platform/DevSecOps support, or discovery work.

This option may be exercised for up to 1800months over the life of the contract. Each Team exercised shall not exceed 12-months.

5.3.2 SMALL SCRUM TEAM

The Contractor shall provide an additional scrum team consisting of up to 3-4 resources comprised of the appropriate technical skill sets to support multiple builds throughout

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

each PoP. Recommended for, focused enhancements, technical tasks, platform/DevSecOps support, or discovery work.

This option may be exercised for up to 1200 months over the life of the contract. Each Team exercised shall not exceed 12-months.

5.3.3 MEDIUM SCRUM TEAM

The Contractor shall provide an additional scrum team consisting of 5-6 resources comprised of the appropriate technical skillsets to support multiple builds throughout each PoP. Recommended for post deployment support, development efforts, backlog, ongoing enhancements, or integrations.

This option may be exercised for up to 1200 months over the life of the contract. Each Team exercised shall not exceed 12-months.

5.3.4 LARGE SCRUM TEAM

The Contractor shall provide an additional scrum team consisting of 6-8 resources comprised of the appropriate technical skillsets to support multiple builds throughout each PoP. For major modernization efforts, high volume feature delivery, or large backlog surges

This option may be exercised for up to 900months over the life of the contract. Each Team exercised shall not exceed 12-months.

5.4 HIGHLY TECHNICAL SCRUM TEAM SUPPORT (OPTIONAL TASK 2) (FFP)

The VA may exercise Scrum team(s) to support HELM PL products and projects with the continuous delivery pipelines as described in PWS sections 5.5 through 5.12. Each exercise may encompass more than one product or project area.

When requirements exceed the capabilities or depth of standard scrum teams, the government Contractor shall provide highly skilled Technical SME Scrum Teams capable of rapidly scaling to meet evolving VA requirements. These teams shall deliver advanced technical expertise to support DevSecOps activities and conduct specialized analyses, including AI driven analytics and solutioning, for needs that extend beyond the planned product backlog associated with HELM Integration and Modernization. SME support may be required for urgent or complex tasks involving data management, implementation support, VA specific system integrations, network engineering, or other advanced technical issues not addressed within standard sprint execution. These teams follow the same activation and pricing structure but include specialized technical skill sets.

Examples of SME skillsets may include, but are not limited to:

- Cloud engineering and architecture (AWS, Azure, VA Enterprise Cloud, Platform One)
- AI/ML engineering, data science, predictive modeling, and advanced analytics
- Cybersecurity engineering, Zero Trust architecture, RMF/A&A Support

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- DevSecOps engineering, CI/CD pipeline development, automation, and platform hardening
- SME knowledge for Enterprise Solution & integration architecture to include (FHIR, ESB patterns)
- API and integration engineering, including VA specific interoperability and FHIR based integrations
- Network engineering, firewall configuration, and VA enterprise network optimization
- Database engineering, ETL development, data migration, and enterprise data governance
- Performance engineering, resiliency engineering, load testing.
- VA-specific system integration (Master Veteran Index (MVI), VistA Interfaces, Lighthouse, APIs etc. as applicable)
- ESB/EAI integration frameworks
- VA Enterprise Logging, monitoring, and observability tools
- Specialized support for VA unique compliance frameworks, configuration standards, and change management requirements

5.4.1 MICRO HIGHLY TECHNICAL SCRUM TEAM (OPTIONAL TASK) (FFP)

The Micro Team shall consist of 2–3 highly skilled technical experts, with the ability to scale based on VA requirements. Minimum required roles and qualifications include: The Contractor shall provide product advanced skillsets in areas related to DevSecOps support.

This option may be exercised for up to 1800 months over the life of the contract. Each Team exercised shall not exceed 12-months.

5.4.2 SMALL HIGHLY TECHNICAL SCRUM TEAM

The Small shall consist of 3-4 highly skilled technical experts, with the ability to scale based on VA requirements. Minimum required roles and qualifications include: The Contractor shall provide product advanced skillsets in areas related to DevSecOps support.

This option may be exercised for up to 1200months over the life of the contract. Each Team exercised shall not exceed 12-months.

5.4.3 MEDIUM HIGHLY TECHNICAL SCRUM TEAM

The Medium shall consist of 4-6 highly skilled technical experts, with the ability to scale based on VA requirements. Minimum required roles and qualifications include: The Contractor shall provide product advanced skillsets in areas related to DevSecOps support.

This option may be exercised for up to 1200 months over the life of the contract. Each Team exercised shall not exceed 12-months.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

5.4.4 LARGE HIGHLY TECHNICAL SCRUM TEAM

The Large Team shall consist of 6-8 highly skilled technical experts, with the ability to scale based on VA requirements. Minimum required roles and qualifications include: The Contractor shall provide product advanced skillsets in areas related to DevSecOps support.

This option may be exercised for up to 900 months over the life of the contract. Each Team exercised shall not exceed 12-months.

5.5 SUPPLY CHAIN PRODUCT SUPPORT (TEAMS) (OPTIONAL HELM PL PRODUCT/PROJECT)

5.5.1 SOFTWARE DEVELOPMENT LIFECYCLE (SDLC) ACTIVITIES

The Contractor shall provide a hybrid SDLC approach that integrates Agile iterative delivery with the documentation, governance, compliance, and quality controls required by VA. The Contractor shall continuously support the iterative build and development methodology to complete all epics and user stories identified in the backlog and shall ensure that delivery practices remain consistent with the SDLC approach defined within PWS Section 5.5 and all related subsections. Prioritization shall be informed by discovery activities, stakeholder input, operational needs, and product Key Performance Indicators/Objectives and Key Results (KPIs/OKRs). KPIs shall be developed in coordination with the VA Product Owner and stakeholders and shall include methodologies that enable objective, lifecycle long evaluation of product performance and user outcomes. The hybrid model shall enable evolutionary (iterative and incremental) product development that produces high-quality outcomes in a cost-effective, timely, and collaborative manner. This requires open communication and coordination across all participants contributing to a project, program, or portfolio with multiple stakeholders and consumers.

The Contractor shall design, configure, develop, enhance, maintain, test, and deploy builds of each product on a recurring basis no shorter than two weeks and no longer than three months throughout the Period of Performance. The Contractor shall provide all deliverables Build and Deployment Packages and artifacts specified herein that satisfy VA documentation, compliance, and code delivery requirements, and shall ensure these artifacts conform to applicable VA policies and enterprise standards. The Contractor shall leverage and reuse relevant content and existing documentation where appropriate to meet the expectations of required package deliverables.

The Contractor shall utilize DevSecOps principles, hybrid SDLC practices, and SAFe frameworks in partnership with VA to further mature the HELM PL. The Contractor shall follow an agile process model for the development of HELM capabilities, including ongoing requirements, elaboration and decomposition, iterative design and solutioning, and continuous integration of working software. The Contractor shall deliver, when applicable, an Updated Technical Design and Product Schedule and Roadmap for each product when applicable. The Contractor shall ensure that all SDLC activities align with evolving VA governance processes, security controls, and enterprise architecture

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

methodologies, allowing the SDLC approach to adapt as VA standards and toolsets mature over the life of the contract.

Deliverables:

- A. Sprint/Iteration Planning Artifacts
- B. Build and Deployment Packages
- C. Compliance Documentation as applicable
- D. Updated Technical Design
- E. Product Schedule / Roadmap
- F. Product Plan / Modernization Roadmap with KPIs/OKRs

5.5.2 CONFIGURATION MANAGEMENT

The Contractor shall:

- Comply with the existing Configuration Management plans in place and offer procedural improvements to VA to mature existing processes.
- Identify the standard and unique aspects of configuration management to be performed for each Agile Product Team (APT) by establishing a Product Configuration Management (CM) Plan (PCMP) which meets OIT VA CM plan requirements. The Contractor shall reflect all CM required activities and standards in each product-level CM plan while determining the unique aspects of the product which require individualized procedures. The COR/ACOR and VA PM shall approve the PCMP.
- Deliver a Recommended List of Configuration Items as part of the PCMP to be placed under configuration and change control. The Contractor shall identify types of configuration items pertaining to each product to be placed under configuration management. Based on Health Portfolio requirements, and the unique needs or nature of each product, the Contractor shall determine the components within each product that must be under configuration control.
- Use a VA-approved tool and repository for all software source code and electronic artifact configuration and version management. The Contractor shall use the VA-approved tool to manage change, activity, issue, action, risk, and other product data as prescribed by VA standards and processes. If assigned a product using tools that are being decommissioned the Contractor shall assist the VA Tools Team in migrating products using other Change and/or Configuration Management tools.
- Ensure that all product software and non-software artifacts are versioned correctly according to VA standards and follow a build/release promotion versioning approach which identifies all major and minor update changes to the components.
- Create Project and Product Artifacts baselined and versioned in the CM repository to allow the tool to show active and past histories of the check-ins and check-outs of all software components, data, and software project engineering documents. Maintain all baselines of software, software builds, and electronic artifacts in the repository, labeling updates and versions according to CM procedures.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- Establish and maintain status reporting on change and configuration management activity and ensure VA approved tools data records and artifacts are filed and updated daily.
- Develop and manage a CM process that supports all necessary changes for the project including changes to Definition of Done, Acceptance Criteria and any other items deemed necessary.
- Create and maintain baselines of all software, builds, and electronic artifacts in the repository, and develop a Version Description Document (VDD) for all product releases.

Deliverables:

- A. Product Configuration Management Plan
- B. Version Description Document

5.5.3 RISK & ISSUE MANAGEMENT

The Contractor shall perform risk management for all work conducted under this TO and shall enter risk information into the Product Risk Management Registry using the VA approved toolset the VA PARS Dashboard, JIRA/GITHUB and/or other OIT approved tools maintained by the VA.

The Contractor shall:

- Comply with the existing Risk Management Plan (RMP) or assist in developing one when an RMP has not yet been established by the VA.
- Use the VA approved tool to create, update, and actively manage a project risk register (risk log) that identifies potential circumstances that may negatively impact project success, describes the possible impacts, and documents actions to reduce or eliminate those impacts. Critical risks, as determined by the VA PM, shall also be recorded in the VA PARS Dashboard, JIRA/GITHUB and/or other OIT approved tools.
- Use the VA approved tool to support and facilitate risk meetings and reviews.
- Collaborate with the project team to actively manage risks and issues, determine level of effort, develop approved mitigations and Plans of Action and Milestones (POA&M), and assess or reassess probability and severity throughout the project lifecycle.
- Assess the status of assigned risks and provide a weekly Risk Management Status Report to the VA for inclusion in the broader Risk Management Registry. When new risks arise that could affect development, testing, or deployment schedules, the Contractor shall notify the COR and VA PM via email within 24 hours. The email subject line shall state: "{Project Name} Risk Alert Notification."
- Summarize the status of active risks and issues according to their risk score. The risk score shall be calculated as defined in the Risk Management Plan. These summaries shall be included in the Contractor's Project Management Plan and provided as needed for periodic reviews, program monitoring, dashboard updates, and other critical decision points.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

Deliverable:

- A. Risk Management Plan (as applicable)

5.5.4 SCHEDULE MANAGEMENT

The Contractor shall create, maintain, analyze, and report individual product Roadmaps and Release Train Schedules in the VA-approved toolset. The Contractor shall provide schedule updates within the VA-approved toolset on a weekly basis. The Contractor shall evolve the roadmap, iteratively maturing. HELM PL support shall include management of patches to mitigate collisions in addition to the PL tracking. HELM PL tracking shall be planned/coordinated to ensure optimized sequencing of releases to avoid patch collisions, and all risks are documented in VA approved toolset within two days of the risk being realized.

The Contractor shall rollup product roadmaps to produce HELM PL Strategic Roadmap.

Deliverable:

- A. Individual Product(s) Roadmap
- B. HELM PL Strategic RoadMap

5.5.5 USER EXPERIENCE MANAGEMENT

The Contractor shall apply Human Centered Design (HCD) principles across HELM PL development, modernization, and sustainment activities to ensure solutions are intuitive, accessible, and aligned with end user needs. All user experience (UX) research, findings, and design decisions shall be documented and maintained in VA approved tools to support traceability, PL visibility, and continuous improvement. The Contractor shall ensure all UX research, insights, artifacts, and design decisions are documented in VA approved tools and linked to requirements, backlog items, and PI Planning artifacts to maintain full traceability and alignment with HELM PL governance.

The Contractor shall:

- Conduct user research studies to understand users' goals, needs, and pain points, applying these insights to define product functionality.
- Engage with product stakeholders to determine the user base, propose survey questions, and identify the best methods for survey distribution.
- Disseminate surveys, collect feedback, and analyze the data to provide insights into how products can be updated based on user input.
- Craft and test design deliverables such as wireframes and prototypes to facilitate usability testing and agile development.
- Document all findings and insights in a User Experience Monthly Report and update the product backlog accordingly

Deliverable:

- A. User Experience Monthly Report

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

5.5.6 USER RESEARCH

The contractor shall conduct user research to identify and validate the needs, workflows, and operational challenges of VA supply chain, logistics, and acquisition stakeholders supported by HELM SCM capabilities. Research activities shall gather input from representative user groups across VA to inform requirements, process improvements, and solution design. Findings shall be incorporated into system development and modernization efforts to ensure capabilities are usable, aligned with mission needs, and supportive of VA's standardized, streamlined, and modern enterprise supply chain objectives. All research shall follow established human centered design practices and comply with VA accessibility and usability standards.

5.5.7 AGILE REQUIREMENTS ELABORATION

The Contractor shall complete an initial Backlog Refinement session with the VA team to properly understand and elaborate business Agile requirements. The outcome of this session shall be a complete review of the initial user stories, consensus among team members, including user stories added as a result of Backlog Refinement. This would be achieved by decomposing Initiatives into Epics, Epics into Stories and tasks that represent stakeholder needs, business requirements, business rules, requirements visualizations and user story elaborations. Backlog Refinement and prioritization with the VA team are continued throughout the product life cycle and shall be managed throughout the PoP. The Contractor shall facilitate any stakeholder briefings, meetings and/or elicitation sessions.

The Contractor shall:

- Ensure all Epics, including Standard Epics, as defined in Attachment 3 Agile Lifecycle Management Library Epic Document– Current Product Line Backlog, are included and executed as appropriate within the overall Agile Backlog Grooming effort.
- Populate the backlog during an initial planning session identifying all features the team considers relevant to building the product.
- Establish initial Unit of measurement (e.g. Story Points) as the estimated relative complexity of user stories.
- Prioritize the backlog of initiatives, epics, stories, and tasks, in collaboration with the VA team using the VA Approved tool to create a refined backlog.
- Execute requirements reviews with stakeholders and record results of reviews using the VA Approved Tool, updating requirements data as a result of the reviews.
- Identify the non-production environmental access that is needed 30 days prior to configuration start.
- Ensure initiatives, epics, stories, and tasks, stakeholder needs, visualizations, stories, and other sources of requirement's information for functional and non-functional requirements are input and maintained in VA Approved Tools to comprise a Requirements Package.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- Ensure all requirements' data is under change control and is fully linked to work items that show traceability to design changes, configurable items, test cases and test results.
- Provide notification upon completion that the Requirements Package is ready for VA Review and Approval.

Deliverables:

- A. Refined backlog Report.

5.5.8 CONTENT DESIGN

The Contractor shall:

- Employ design process management by breaking designs into small, bite-sized implementations and collecting data from each deployment to inform priorities and decisions in the next iteration.
- Write and edit plain language content. See <https://design.va.gov/> for the style guide.
- Ensure consistency and continuity in Health product information architecture, including URL schema, page layout, menus and navigation, user flows, and search engine optimization. Work with all VA Product Teams to incorporate new, both authenticated and unauthenticated, content and tools, into the Information Architecture Document to be included in the Solution Architecture Package (PWS Section 5.9.1 Solution Architecture Planning and Execution) of HELM products.
- Craft, test, and deploy design deliverables, including Wireframes, low- and high-fidelity prototypes, or interactive web forms to be included in the Solution Architecture Package (PWS Section 5.9.1, Solution Architecture Planning and Execution) to facilitate usability testing and agile development of health products. As appropriate, create and update prototypes to conduct facilitated demos or usability testing to elicit feedback for improvements to the design.
- Develop designs that adhere to VA's application of the U.S. Web Design System, available on <https://design.va.gov>. If the Contractor determines a need for a new pattern, the Contractor shall collaborate with PM/COR to design that pattern. The Contractor shall work with the Enterprise Architecture team to build and validate new enterprise design pattern and document within the User Experience Design Document
- Support and comply with all user experience guidelines and standards as defined by VA, currently at <https://department-of-veterans-affairs.github.io/va-digital-service-handbook/>

5.5.9 PRODUCT TESTING

The Contractor shall perform product-specific testing activities in alignment with the hybrid SDLC model, Agile development practices, and continuous delivery approach described in this PWS. The Contractor shall conduct testing on a recurring, iterative basis to validate functionality, performance, accessibility, security, and interoperability of each product throughout the development lifecycle. Testing shall be integrated into

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

every sprint and release cycle and shall comply with VA policy, VA governance processes, and VA-approved testing requirements, including Health Portfolio Jira Management Requirements where applicable.

The Contractor shall design, implement, and maintain automated test scripts wherever feasible to improve coverage, reduce manual effort, and support consistent, repeatable validation of product functionality. Automated regression testing and continuous integration capabilities shall be leveraged using VA TRM-approved tools. The Contractor shall support manual testing where necessary for specialized validation or compliance activities.

The Contractor shall work collaboratively with product teams, VA stakeholders, and dependent solution groups to define test conditions, maintain alignment with evolving requirements, validate acceptance criteria, and ensure readiness for release. The Contractor shall support continuous improvement by refining test approaches, expanding automation capabilities, and improving test quality over the Period of Performance.

5.5.9.1 INTEGRATED TESTING ACTIVITIES

The Contractor shall plan, execute, document, and maintain testing activities across all phases of the system lifecycle, including user story, sprint, build, release, and production readiness testing. At a minimum, testing shall include:

- Unit testing
- Functional testing
- Accessibility testing (Section 508)
- System testing
- Reliability testing
- Usability testing
- Interoperability testing
- Regression testing (automated where feasible)
- Security testing
- Performance and load testing

The Contractor shall conduct testing of non-functional requirements, including installation, configuration, backout, rollback, failover, and recovery procedures. Testing shall utilize continuous integration and automated regression capabilities using VA TRM-approved tools, such as Selenium, JUnit, NUnit, Jenkins, GitLab CI/CD, Cucumber, Postman, and Cypress, provided they are approved at the time of use.

The Contractor shall participate in and support enterprise and compliance testing activities, including:

- Security assessments
- Accessibility compliance reviews
- Performance and load testing events
- Technical standards validation

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- Architectural compliance reviews
- User Acceptance Testing (UAT)
- Initial Operational Capability (IOC) validation

Security scanning shall be performed using VA-approved tools, including Web Application Security Assessments (WASA), static code analysis (e.g., Fortify), and dependency/vulnerability scanning solutions. The Contractor shall remediate identified vulnerabilities in accordance with VA-defined severity timelines.

5.5.9.2 TEST PLANNING AND DOCUMENTATION

The Contractor shall:

- Develop and maintain a Test Plan within the VA Quality Manager tool.
- Provide complete Test Strategy and Test Execution content using VA-provided templates.
- Enter all test cases, test scripts (automated and manual), test data, execution results, and supporting artifacts into the VA-approved tool.
- Maintain and update the Requirements Traceability Matrix (RTM) to ensure bi-directional traceability between requirements, test cases, defects, and releases.
- Update all testing artifacts daily to ensure visibility and accuracy of status.
- Place all testing artifacts under version control in a VA-approved repository.

5.5.9.3 DEFECT MANAGEMENT

The Contractor shall:

- Log all defects in the VA-approved tool within one business day of identification.
- Assign severity and impact levels consistent with VA-defined criteria.
- Support the VA PM and COR/ACOR in defect prioritization and backlog grooming.
- Track defects through resolution, retesting, and closure.

Defects shall be remediated within the following maximum timeframes:

- Critical – 5 business days
- High – 10 business days
- Medium – 30 business days
- Low – As prioritized by the VA PM

Defects shall not be closed without documented validation evidence and successful retesting.

5.5.9.4 REPORTING

The Contractor shall provide:

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- Test execution status reporting per sprint and per release.
- A Test Summary Report at the conclusion of each release (or sprint if required).
- Performance and load testing reports.
- Security scan results and documented remediation evidence.
- Daily defect status updates.

All assessment results from Contractor-led and VA-led reviews shall be consolidated in the VA-approved tool for reporting and audit purposes.

5.5.9.5 RELEASE READINESS CRITERIA

Prior to production deployment, the Contractor shall:

- Execute no less than ninety-five percent (95%) of planned test cases for the release.
- Ensure all Critical and High defects are resolved or formally accepted by the VA PM.
- Ensure zero (0) open Critical or High security vulnerabilities unless risk acceptance is formally approved by the Authorizing Official (AO).
- Obtain documented VA PM approval to proceed to production.

Deliverables:

- A. Test Plans
- B. Test Cases
- C. Test Scripts (including automated test scripts where applicable)
- D. Test Execution Reports
- E. Defect Report
- F. Defect Evidence Validation Report
- G. Requirements Traceability Matrix (RTM)
- H. Test Summary Report(s) (per sprint and/or release as required)

5.5.10 PRODUCT ARCHITECTURE

The Contractor shall lead architecture and discovery activities for each assigned HELM product, ensuring that solution's intent, requirements, and technical direction are clearly defined, documented, and aligned with PL guidance. The Contractor shall be responsible for translating business needs into product-specific architectural models, epics, features, and stories, while managing product-level risks, dependencies, and design considerations. The Contractor shall work directly with VA customers and product stakeholders to understand operational needs, prioritize capabilities, establish the product vision and roadmap, and ensure that the product's technical architecture supports both near-term delivery and long-term modernization objectives. The Contractor shall maintain accurate and current architecture artifacts and guide work through the product team as described below.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- Perform product-level discovery and planning for the assigned product, including review of existing VA solutions, dependent products, and business processes specific to that product.
- Build and maintain a HELM-wide SAFe Architectural Runway by working with PL leadership, solution architects, and dependent teams to define and evolve shared technical foundations, architectural enablers, integration points, and cross product capabilities; update quarterly prior to each PI.
- Work closely with VA customers for that product to understand requirements, map needs to VA capabilities, and support refinement of epics into features and stories.
- Develop AS IS Architecture Models for the specific product using VA-prescribed and enterprise-approved architecture formats (such as DoDAF and UAF), capturing user feedback, technical baselines, and product-specific process flows.
- Develop TO BE Architecture Models for the product using the current VA-approved enterprise architecture methodology, representing the future-state architecture that aligns with Product Line and enterprise direction.
- Develop and maintain current architecture diagrams (logical, network, and dataflow) for the product, update each release and consistent with the enterprise architecture modeling approach in use at the time.
- Develop a Solution-Level Roadmap for the product.
- Define solution-level (product-specific) epics with acceptance criteria and ensure alignment to product goals and Product Line architecture.
- Develop the Solution Architecture for the product, including technical, business, and data components, in accordance with the architectural modeling standards and practices adopted by VA during the period of performance.
- Support early user interface and technical prototypes for the product.
- Support business process modeling for product workflows.
- Guide product team execution by maintaining requirements, updating solution intent, and ensuring alignment to planned KPIs during PI execution.

Product-Level Deliverables:

- A. AS IS Architecture Model
- B. TO BE Architecture Model
- C. Architecture Diagrams
- D. Solution-Level Roadmap (product-specific)
- E. Product-Specific Data Models
- F. User Research Artifacts
- G. Solution (Product) Roadmap
- H. Product Line SAFe Architectural Runway

5.5.11 DATA MANAGEMENT AND MIGRATION SUPPORT

The Contractor shall provide support for database solutions and design strategies for data migration during VA site implementations, and shall supply resources for site data mapping, extraction, transformation, migration, analytics, and validation from VA legacy systems (e.g., AEMS/MERS, GIP, Maximo) to DMLSS, LogiCole, and other systems as

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

required. Data may need to be delivered to third parties (e.g., MEDLOG) in accordance with provided standards. The Contractor shall comply with Section 5.5 SDLC for all data migration development efforts and shall adhere to applicable government and VA standards, including security and organizational controls for scripts, tools, and artifacts.

5.5.11.1 DATA TOOLS DEVELOPMENT AND TESTING SUPPORT

The Contractor shall design, develop, test, update, and manage tools to obtain and manage data sets from disparate sources, including subject matter expert input. The Contractor shall provide project management plans for these tool development efforts and be accountable to cost and schedule; tool development and updates shall follow VA TRM-approved technologies and practices, as applicable.

Key activities include:

- Developing and testing data tools to obtain and manage data sets from various sources.
- Managing updates to tools and supporting ongoing operations aligned to the project management plan.
- Providing project management plans and periodic updates that govern scope, schedule, and cost for data tool development and testing.

5.5.11.2 DATA EXTRACTION AND ANALYTICS

The Contractor shall perform mapping, extraction, transformation, migration, and analytics for data from disparate legacy sources, and provide analytical support to establish and refine extraction, transformation, and migration standards and processes. The Contractor shall troubleshoot and resolve identified data issues, and provide periodic input to updates and/or assist in establishing the Data Migration Plan (DMP), including schedules where one is not already established by the VA. The Contractor shall adhere to government standards where applicable for the security and organization of extraction and transformation scripts.

Key activities include:

- Developing, organizing, and maintaining data extraction scripts.
- Establishing and updating the Data Migration Plan and schedule (as applicable).
- Delivering mapped and transformed data to VA systems and approved third parties (e.g., MEDLOG) per provided standards.

5.5.11.3 DATA MAPPING AND VALIDATION

The Contractor shall perform comprehensive data mapping analysis to ensure data from legacy systems is identified, cleansed, enriched, and structured appropriately for migration. The Contractor shall develop and provide a Data Mapping and Validation Plan, execute validation activities, analyze results, and identify corrections for any data issues. A Data Mapping Document shall be maintained to reflect the authoritative mapping rules, transformations, and quality checks for each migration.

Key activities include:

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- Producing and maintaining a Data Mapping and Validation Plan.
- Conducting data profiling, cleansing, enrichment, and validation aligned to VA standards.
- Generating Data Mapping Analysis and Validation Results and implementing corrective actions.

5.5.11.4 MIGRATION PLANNING, ENVIRONMENT SUPPORT, AND TESTING

The Contractor shall support the migration of products between environments (e.g., development, test, staging, production) by coordinating with infrastructure points of contact and providing technical support for testing, configuration, and documentation. The Contractor shall develop and provide a Migration Support Plan that identifies tasks, schedules, and roles, along with a Migration Test Plan that outlines the testing approach and pass/fail criteria; execution results shall be documented in a Migration Test Summary Report.

Key activities include:

- Coordinating environment migrations with infrastructure POCs.
- Providing technical support for migration testing, configuration, and documentation.
- Developing and maintaining migration planning and testing artifacts that confirm readiness and quality.

Deliverables:

- A. Data Tools Development and Testing Project Management Plans — due four (4) weeks after kickoff
- B. Updates to the Data Tools Development and Testing Project Management Plans — as required
- C. Data Tools Delivery and Updates — as defined in the Project Management Plan and as needed
- D. Data Extraction Scripts — developed and updated as needed
- E. Data Migration Plan and Schedule (or updates, as applicable) — as needed
- F. Data Mapping Document
- G. Data Mapping and Validation Plan
- H. Data Mapping Analysis and Validation Results
- I. Data Migration Support Plan
- J. Data Migration Test Plan
- K. Data Migration Test Summary Report

5.5.12 TRAINING SUPPORT

The Contractor shall provide comprehensive training support for product users to ensure effective adoption, operational readiness, and ongoing proficiency. Training shall comply with VA standards, use VA approved platforms, and be tailored to accommodate both new and existing users.

- The Contractor shall provide training based on requirements which can contain the following: Develop and Deliver Virtual Training Provide virtual learning

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

sessions, including instructor led virtual classes, webinars, demonstrations, and interactive training modules to support onboarding and ongoing education for HELM Product Line users.

- **Create Training Materials and Artifacts**
Develop and maintain user focused training materials, including presentations, guides, reference documents, job aids, videos, and self-paced learning content. All materials shall be stored in VA approved repositories.
- **Support New and Existing Users**
Deliver training designed for both new users requiring introductory instruction and existing users requiring refresher training or updated instruction for new functionality or existing functionality due to bug fixes, enhancements, or procedural changes.
- **Provide Post Training Support**
Offer follow up sessions, office hours support, and Q&A opportunities to ensure users can effectively apply learned content and incorporate updated processes related to HELM Product Line solutions.
- **Maintain Training Schedules and Attendance**
Coordinate with VA stakeholders to schedule training sessions, manage registration, track attendance, and report training metrics in VA approved formats.
- **Update Training Content with Each Release**
Enhance or revise training content to align with system updates, new features, user interface changes, bug fixes or workflow modifications resulting from HELM Product Line releases or enhancements.
- **Develop TMS Training when applicable**
- **Provide comprehensive Training Plan**

Deliverables (Optional):

- A. Training Plan
- B. Virtual Training Schedule
- C. Training Materials and User Guides
- D. Training Attendance Reports
- E. Updated Training Content per Release
- F. Recorded Training Webinar

5.5.13 AI/ML OPTIMIZATION AND PREDICTIVE ANALYTICS

The Contractor shall incorporate artificial intelligence and machine learning (AI/ML) capabilities into for HELM PL to optimize products and reduce operational risks.

The Contractor shall:

- Implement AI/ML algorithms to enhance predictive forecasting and provide near real-time data insights into inventory levels and demand. Provide an AI/ML Model Validation Report to describe and validate these algorithms.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- Develop automated capabilities for the identification and validation of product substitutions during supply disruptions to maintain continuity of care. Provide a Predictive Forecasting Analysis defining these capabilities.
- Provide actionable analytics to empower stakeholders with information needed for continuous improvement and operational excellence.
- Develop and maintain a Centralized Supply Chain Dashboard to monitor purchase orders, demand fluctuations, and inventory bottlenecks in real time.
- Provide a Product Substitution Automation Guide to describe how product substitutions are implemented by the system.

Deliverables:

- A. AI/ML Model Validation Report
- B. Predictive Forecasting Analysis
- C. Centralized Supply Chain Dashboard
- D. Product Substitution Automation Guide

5.6 RELEASE SUPPORT (OPTIONAL HELM PL PRODUCT/PROJECT)

The Contractor shall support the VA DevSecOps Release Process. The Release Process governs deployment of new functionality, enhancements, and defect remediation in alignment with the VA DevSecOps Release Framework. The Contractor shall use the VA approved release calendaring process and toolset (e.g., ServiceNow) to track release activities, dependencies, special works in progress, and production deployment events.

The Contractor shall provide all required information to populate and maintain ServiceNow release calendar entries for each release.

The DevSecOps Release Process includes pre-release and release activities and may require coordination with a Release Train Engineer (RTE) Lead.

5.6.1 PRERELEASE SUPPORT

The Contractor shall support the HELM PL Release Process throughout the build lifecycle, ensuring alignment with HELM Agile, DevSecOps, and CI/CD workflows. VA Release Agents shall review artifacts for completeness, traceability, and compliance with Release Process standards. The Contractor shall integrate secure code scanning, CI/CD pipelines, configuration validation, dependency inventories, and artifact promotion controls.

The Contractor shall prepare the Build Release Package, including:

- Production Operations Manual (POM) / Technical Manual (workflows, RACI, dependencies, monitoring indicators)
- User Guide for business and HELM PL users
- Version Description Document (VDD) (configuration, traceability, audit support)
- Transition Plan (architecture, interfaces, environments, pipeline dependencies)

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- Deployment & Installation Guide (deployment patterns, rollback, contingency, Disaster Recovery (DR), security keys)
- All ATO related documentation, including Risk Management Framework (RMF), scanning evidence, and continuous monitoring items.
- The Contractor shall collaborate with the PM, HELM Leadership, and stakeholders to develop a comprehensive Build Release Package that satisfies all HELM release readiness, deployment, and governance requirements.
- VA assigned Release Agents shall perform ongoing reviews of HELM product artifacts within VA mandated repositories and provide feedback on documentation completeness, traceability, and compliance with Release Process standards.
- The Contractor shall ensure that code commits, test results, configuration items, dependency inventories, and deployment artifacts meet HELM quality gates and are properly linked in HELM repositories, backlogs, and pipeline orchestration tools.
- Pre-Release Support shall integrate HELM's DevSecOps toolchain, including automated CI/CD pipelines, secure code scanning, configuration validation, and artifact promotion controls.

All prerelease activities shall comply with HELM PL governance, VA Agile/DevSecOps policies, VA security and quality standards, and CI/CD integration requirements.

Deliverable:

A. Build Release Package

5.6.2 ASSESSMENT AND AUTHORIZATION (A&A) SUPPORT

The Contractor shall provide documentation, support, and coordination with VA Information Security Officers (ISOs), Field Security Services (FSS), and the Office of Cyber Security (OCS) to support Authority to Operate (ATO) compliance.

The Contractor shall:

- Support assessment requirements in accordance with VA Directive 6500 and VA Handbook 6500.
- Participate in vulnerability scans and quality reviews in accordance with NIST SP 800-53 Rev.5 and other applicable guidance.
- Remediate critical and high severity vulnerabilities identified through government scans.
- Provide vulnerability scanning reports and risk assessments in accordance with NIST SP 800-30 Rev. 1.
- Comply with OMB Memorandum 11-11 and VA enterprise cybersecurity strategy requirements.
- Support secure authentication via SAML tokens.
- Develop and maintain A&A artifacts required for ATO requests as described in NIST SP 800-37 Rev. 2.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

A&A artifacts include, but are not limited to:

- Privacy Impact Assessment (PIA)
- Risk Assessment (RA)
- Security Configuration Checklist (SCC)
- System Interconnection Agreements (MOU/Interconnection)
- Interconnection Security Agreement (ISA), as applicable

Deliverables:

- A. Vulnerability Scanning Reports and Assessments
- B. A&A Artifacts Required by the A&A Review Process

5.6.3 INITIAL OPERATING CAPABILITY (IOC) SUPPORT

The Contractor shall support the Initial Operating Capability (IOC) evaluation for HELM PL product line, including Asset Management, Inventory Management, Prosthetics, and other supply chain modernization solutions. IOC is a limited production release conducted after all testing has been completed and user acceptance has been granted. During IOC, the Contractor shall assist HELM PL by tracking issues, investigating defects, supporting remediation activities, and ensuring that IOC entry and exit criteria are met for each applicable HELM product.

The Contractor shall support a 10-day errorfree IOC period in the production environment. All issues and defects identified during IOC shall be documented in the Defect/Fix Status Report. For each defect, the Contractor shall prepare an IOC Defect Resolution Plan that identifies the corrective action, required updates to software code or documentation, and impacts to schedule. Upon COR approval, the Contractor shall execute the approved plan and deliver updated software source code, compiled code, and supporting documentation.

Following any defect correction, the IOC period shall continue for a minimum of five consecutive errorfree business days before IOC may be exited. The Contractor shall coordinate installation and configuration of updates at VA test sites and support validation of fixes across the relevant HELM product lines.

The Contractor shall support all IOC entry and exit activities and shall prepare and deliver an IOC Entry Request and final IOC Exit Summary documenting completion of all requirements and readiness for full deployment.

Deliverables:

- A. Defect/Fix Status Report
- B. IOC Defect Resolution Plan
- C. Updated Software Source Code, Compiled Code, and Supporting Documentation
- D. IOC Entry Request and IOC Exit Summary

5.6.4 RELEASE AND DEPLOYMENT SUPPORT

The Contractor shall support both release activities (preparing, documenting, packaging, and obtaining required approvals for a software version) and deployment activities (executing the movement of that version into production). The Contractor shall

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

ensure all Pre-Release, A&A, and IOC criteria have been met before deployment occurs. The Contractor shall coordinate each release with VA technical staff, integration partners, and teams supporting interfacing systems to resolve issues and ensure all required components are migrated to the appropriate technical environments as planned.

The Contractor shall participate in release and deployment planning and coordination meetings, verify that deployment checklists, prerequisites, and dependencies are complete, and confirm readiness for production migration. The Contractor shall prepare and maintain all documentation and artifacts that make up the Release and Deployment Support Package, which includes, at a minimum:

- Solution Deployment Package (SDP), including smart scripting and all required artifacts covering Release Management, Product Documentation, and Product Support phases
- Updated Build Release Package reflecting final build and deployment changes
- Release Notes describing new features, fixes, and configuration changes
- Updated design documents
- Final source code
- Evidence of compliance with the VA DevSecOps Release Framework
- Final technical and operational documentation reflecting any changes during IOC or production deployment

The Contractor shall also define the processes, coordination activities, responsibilities, and overall approach for carrying out all release and deployment tasks in the Release and Deployment Support Plan.

The Contractor shall ensure these materials remain current and are recorded using VA-approved tools that support documentation, workflows, and release tracking. To support the complete lifecycle of preparing and delivering a release into production, the Contractor shall perform activities that span planning and readiness, deployment execution, post-deployment monitoring, and release closure.

The following subsections define the major activity areas required to ensure each release is prepared, deployed, validated, and completed in a controlled and coordinated manner.

Execute Deployment Activities

The Contractor shall carry out deployment activities to ensure that approved releases are successfully migrated into the production environment. These activities include:

- Providing deployment support for all scheduled releases
- Promoting validated build artifacts through approved CI/CD pipelines
- Executing deployment according to documented strategies, procedures, and rollback plans

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- Validating configurations, interfaces, and data flows immediately following deployment
- Documenting observed results and resolving issues encountered during execution

Monitor and Validate Production Deployment:

The Contractor shall perform monitoring and validation activities following deployment to ensure the operational stability of the released product. These activities include:

- Monitoring and documenting the operational solution immediately following deployment
- Providing oversight and support for a minimum of 90 days to ensure a stable transition to operations support
- Validating system performance, integrations, and dependencies in the production environment
- Supporting VA in any required post-implementation reviews (PIR)
- Providing information, updates, and artifacts needed for VA to evaluate deployment results and determine corrective actions

Complete Release Acceptance and Closure Activities:

The Contractor shall complete the release lifecycle by ensuring acceptance, documentation updates, and closure actions are performed in coordination with VA stakeholders. These activities include:

- Coordinating with VA to confirm acceptance of the deployed release
- Completing all documentation updates, issue resolutions, and closure activities using VA-approved tools
- Utilizing the VA-approved calendaring process to track release and implementation schedules, special works in progress, and other deployment activities in the production environment
- Providing required data and updates to ensure the VA-approved calendaring process is accurately populated and maintained
- Supporting enterprise scheduling, communication, and visibility requirements
- Ensuring final documentation reflects updates made during IOC or production deployment and resolving any discrepancies identified by VA

Deliverables:

- A. Release and Deployment Support Package including the Solution Deployment Package (SDP)
- B. Release and Deployment Support Plan

5.7 POST DEPLOYMENT SUPPORT (OPTIONAL HELM PL PRODUCT/PROJECT)

Upon completion of the first product build release and each subsequent release for HELM managed software, the Contractor shall provide defect management support and coordination. Within Incident Management, defect management shall follow established VA policies and be documented through tickets as a "bug" or "defect", to indicate an

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

identified problem that is not working as designed. Defect correction may be planned for inclusion in a subsequent production release, emergency release, or prioritized in the product backlog. Defects may be identified by the VA Project Manager (PM), end users, the OIT Enterprise Service Desk (ESD), Help Desk, the Contractor, or Business/Product Owners. For each defect identified, the Contractor shall develop and submit Post Deployment Defect Resolution Plan that includes severity classification, triage results, remediation approach, timeline, and required updates to code and artifacts maintained in VA approved tools. Following the VA PM's approval of the Contractor Post Deployment Defect Resolution Plan, the Contractor shall execute the approved plan.

Provide Post-Deployment Hypercare

- Provide 90 days of post-deployment monitoring (hypercare) to ensure stable operations, defect mitigation, and seamless transition to sustainment support.
- Coordinate with the ESD for issue routing and Tier II/Tier III support.

The Contractor shall continue to provide post sustainment defect support for 90 days after contract completion (the warranty period).

Tiered Support Model assistance – handled by OIT ESD.

- Tier 1 – Application error messages – handled by ESD.
- Tier 2 – Report generation, production research, database updates, batch job support shall be handled by the Contractor during VA approved support hours.
- Tier 3 – Application code changes, defect corrections, security compliance updates, and related remediation – shall be handled by the Contractor during VA approved support hours.

Tier 2 and Tier 3 Response Requirements

Severity Code	Tier 2 Initial Response	Escalation to Tier 3	Tier 3 Response	Tier 2 Update Frequency	Resolution Time**
1 – Critical	15 minutes	0–15 minutes	15 minutes	Hourly or on call until resolved	0–2 business hours
2 – Serious	1 hour	30 minutes	1 hour	Hourly or on call	2–4 business hours
3 – Moderate	4 hours	1 hour	4 hours	Daily	4–8 business hours

Resolution times shall align with the established Service Level Agreement (SLA) for each product.

In the event a defect or bug causes a high priority or critical outage rendering the software application and/or infrastructure to be inoperable and triggers a major incident. The responsible application team shall initiate the major incident steps outlined within the HELM Operations and Maintenance Plan to restore the effected application and/or

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

infrastructure. The Contractor shall create and distribute an After-Action report within 24 hours via email to VA PM, COR/ACOR and Business Stakeholders.

Deliverables:

- A. Post Deployment Defect Resolution Plan
- B. After Action Report

5.7.1 AFTER BUSINESS HOUR SUPPORT

The Contractor shall maintain a phone tree support structure to ensure timely escalation and coordination during weekends and other periods outside standard support hours when critical or high severity issues arise. Technical support teams follow established VA procedures and shall integrate with VA's ESD to ensure proper resolution or escalation (Tier 2, 3) of all issues within established time frames.

The Contractor shall follow VA incident response procedures. The Contractor shall support a non-business hours rotation schedule to respond to HELMs monitoring and alerting platform to incidents on monitored HELM applications. The Contractor shall provide specific escalation policies based on the needs of the individually supported products

5.8 VALIP SUSTAINMENT SUPPORT (OPTIONAL HELM PL PRODUCT/PROJECT)

VALIP provides a modern and industry standard platform for real-time interoperability for the HELM PL. Built on a scalable and highly available OpenShift Kubernetes containerized framework, VALIP currently uses Red Hat, InterSystems and DataBricks integration (subject to change), data management and API technical components to orchestrate data sharing and services across the PL. This shared orchestration layer simplifies infrastructure maintenance of applications in the VAEC while adhering to a DevSecOps framework to integrate security into all phase of software development. VALIP enables data exchange between legacy and new systems in the enterprise through simple messaging or abstraction through an API layer or publish subscribe model that hides complexities of the actual implementation from consumers.

VALIP shall serve as a comprehensive, cloud-based ecosystem, delivering seamless integration and interoperability for all products within the VA Supply Chain Portfolio, which include commercial off-the-shelf (COTS), government off-the-shelf (GOTS), and Software-as-a-Service (SaaS) solutions. The VALIP platform is designed to facilitate comprehensive data integration across diverse systems, supporting unified supply chain operations while leveraging the scalability, flexibility, and high availability of a modern cloud-native environment.

Utilizing robust API management, near real-time messaging, and service orchestration, VALIP ensures adaptability to the evolving needs of the VA supply chain. As a cloud-based ecosystem, VALIP must interface with the Oracle Health Electronic Health Record (EHR) and the Integrated Financial Management System (iFAMS) for the

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

purpose of streamlining the supply chain workflows, clinical care, and financial processes.

VALIP's cloud-based ecosystem shall enable precise tracking of inventory, including medical devices and pharmaceuticals, from procurement through patient utilization. This shall ensure a more effective supply chain management operation by way of better end-to-end visibility and connecting demand, asset, distributor, and supplier data within a secure, cloud-enabled network.

VALIP shall incorporate artificial intelligence and machine learning (AI/ML) to optimize supply chain operations, reduce risks, enhance predictive forecasting, and maintain continuity of patient care by minimizing inventory bottlenecks and disruptions. Actionable analytics shall empower stakeholders with the information needed for continuous improvement and operational excellence.

The VALIP cloud-based ecosystem shall enable automated data exchange between internal and external supply chain partners, automate the identification and validation of product substitutions during supply disruptions, as well as enable the provisioning of a centralized dashboard to monitor purchase orders and demand fluctuations in real time.

5.8.1 VALIP CLOUD ECOSYSTEM DEVELOPMENT AND MANAGEMENT

The Contractor shall update the current design and implement, and maintain VALIP as a comprehensive, cloud-based ecosystem that delivers seamless integration and interoperability for all products within the HELM Product Line. The Contractor shall ensure the platform supports diverse systems, including COTS, GOTS, and SaaS solutions, while leveraging the scalability, flexibility, and high availability of a modern cloud-native environment and adhering to VA's TRM. To define and govern this environment, the Contractor shall develop and maintain a VALIP Solution Architecture Package that documents the overall architecture, integration patterns, and orchestration framework supporting enterprise interoperability.

The Contractor shall:

- Architect VALIP to serve as the central integration hub, facilitating comprehensive data integration across diverse supply chain systems, as defined within the VALIP Solution Architecture Package.
- Utilize robust API management, near real-time messaging, and service orchestration to ensure the platform adapts to the evolving needs of the VA supply chain, with interfaces and data exchanges documented through Interface Control Documents (ICDs).
- Establish a secure, cloud-enabled network that connects providers, distributors, and suppliers to provide end-to-end visibility, with interfaces and connectivity standardized and maintained via ICDs.
- Ensure the ecosystem supports high availability and disaster recovery requirements to maintain continuity of patient care and minimize inventory

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

bottlenecks, supported by a Cloud Capacity and Scalability Plan that defines performance thresholds, scaling strategies, and resource provisioning.

Deliverables:

- A. VALIP Solution Architecture Package
- B. VALIP Interface Control Documents (ICD)
- C. Cloud Capacity and Scalability Plan

5.8.2 INTEGRATION AND INTEROPERABILITY

The Contractor shall develop and manage integrations to streamline HELM PL and supply chain workflows, clinical care, and financial processes. As the primary messaging and data middleware solution for the HELM PL, the Contractor shall ensure VALIP interfaces with critical incumbent systems, enterprise systems, including the Oracle Health EHR and iFAMS, and other integrations as applicable. Moreover, the Contractor shall ensure that all required and essential inbound & outbound messaging formats are supported as determined by the information systems in the HELM PL. To ensure consistency, accuracy, and governance across all integrations, the Contractor shall develop and maintain a Data Mapping and Validation Plan that defines data standards, transformation logic, and validation procedures.

The Contractor shall:

- Develop and maintain bi-directional interfaces between VALIP and Oracle Health EHR to ensure logistics data is fully integrated with clinical records, aligned to defined data mappings and validation rules within the Data Mapping and Validation Plan.
- Develop and maintain interfaces between VALIP and iFAMS to streamline financial processes and ensure financial data integrity regarding procurement and inventory, supported by standardized data mapping and validation procedures.
- Develop and maintain one-way and bi-directional interfaces between incumbent and modernized financial management systems to ensure uninterrupted mission-critical financial operations, validated through execution of Integration Test Plans and Results.
- Provide a Data Mapping and Validation Plan defining the data mappings used to implement the above interfaces.
- Provide an Integration Test Plans and Results document with test plans and test results validating the above integrations.
- Enable automated data exchange between internal and external supply chain partners. Provide an External Partner Connectivity Report defining these data exchange mechanisms.
- Ensure precise tracking of inventory, including medical devices and pharmaceuticals, from procurement through patient utilization, supported by validated integrations and tested interfaces as documented in Integration Test Plans and Results.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

Deliverables:

- A. Integration Test Plans and Results
- B. Data Mapping and Validation Plan
- C. External Partner Connectivity Report

5.9 BUILD AND DEVELOPMENT (OPTIONAL HELM PL PRODUCT/PROJECT)

The Contractor shall continuously support the iterative release and configuration methodology to complete all epics and user stories identified in the backlog.

5.9.1 SOLUTION ARCHITECTURE PLANNING AND EXECUTION

The Contractor shall create a Solution Architecture Package that includes the initial business, systems, application, and data architectures for the new features and capabilities using an architecture framework, approved by the PM/COR or ACOR. These documents shall be updated utilizing VA approved templates and GitHub or VA approved tool when appropriate and approved by the COR or ACOR/PM in each subsequent Sprint. Each subsequent update shall include a Changes Page, which specifies the updates made to the document for review and approval by the COR or ACOR/PM. The Contractor shall also outline any initial gaps, questions or challenges that may hinder progress in future Builds or Sprints.

The Contractor shall:

- Support the setting up of all needed development and test environments as required to complete required build development and testing. Coordinate with VA to ensure alignment with all development and test environments. The Contractor shall work with VA to ensure required specifications are provided no later than 30 days prior to environment need date.
- Develop, support, and/or maintain the VA Authority to Operate (ATO) to obtain/maintain approval, as required. Required ATOs must be obtained prior to build release and ATO approval timelines, including all necessary security scanning and remediations, must be considered in build planning activities.
- Develop and deliver automated build and automated publishing capabilities to schedule jobs and support continuous integration for every sprint. Automated build tools shall be in compliance with the approved list from the One-VA TRM and code shall be demonstrable and stable enough to be promoted to another environment without issue by evidence of the status of tests and results in the VA approved tool (currently GitHub/Jira).
- When developing an interface, the Contractor shall identify such issues with the Government for proper Integration Control Registration (ICR) and await approval from the Government to proceed.
- When developing an interface, the Contractor shall ensure the requirements shall be added to the backlog with a priority to integrate the product into the Product Line Architecture.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- When developing an interface, the Contractor shall also ensure the product complies with Product Line Interface Control Documents (ICDs), if existing, or assist in the creation of new ICDs to support new integrations that have been approved through the Configuration Control Board.

Deliverables:

- A. Solution Architecture Package
- B. ICR Issues (As Applicable)
- C. ICD (As Applicable)

5.9.2 BUILD PLANNING

Backlog grooming and prioritization are continued throughout the product life cycle and shall be managed throughout the PoP. The Contractor shall develop builds of each product on a continuous basis no shorter than two weeks but no longer than three months in duration. The Contractor shall develop and deliver a Build Plan in collaboration with the project team prior to beginning the build. The Build Plan is the scope of work which shall be completed in the agreed upon build timeframe. Each build must end with a release production. Each build shall be made up of individual sprints, be fully tested by end users, and end in a release to production. The Build Plan must be completed prior to the start of the build timeframe. After the build plan is approved and the team is ready to start the build, the three months or less build cycle shall start. Planning for future builds shall occur during the execution of current builds.

The Contractor shall maintain the product backlog, continuously, for each build, in every release and throughout the life of the PoP within the VA approved tool. All activity scheduled in each build and backlogs shall be captured and have status showing all work items, changes, impediments, and retrospectives. All data and artifacts in the VA approved tool shall be fully linked to requirements data and test data.

The Contractor shall:

- Facilitate review, elaboration, and prioritization of the backlog. This backlog grooming shall occur continuously throughout the build to ensure the highest product priorities are being met.
- Facilitate selection of prioritized items from the product backlog to be included in the next build with approval of VA COR or ACOR/PM and incorporate those items into a Build Plan for posting to VA approved tool.
- Conduct an Initial Design Review with stakeholders to ensure the design is technically and fiscally able to be completed during the build.
- Provide support for identification of field sites, test environments, acceptance criteria, and ATO requirements.
- Coordinate in the validation or creation of Interconnection Security Agreement/Memorandum of Understanding (ISA/MOU) and Service Level Agreements (SLA) for partner dependencies that specifically highlight the commitment of partners to associated release. The ISA specifies the

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

technical and security requirements of the interconnection and the MOU defines the responsibilities of the participating organizations.

The Contractor shall provide a Build Test Plan to COR or ACOR/PM for approval prior to initiating any development activities. This plan shall include both Contractor and VA testing activities, dependencies, and descriptions of the interfaces and interactions between solution components that are needed to test and validate. The Build Test Plan shall specify the types and scope of testing to be conducted during each product build (e.g. unit, functional, accessibility, system, reliability, usability, interoperability, regression, security, performance). The Contractor shall include testing related to non-functional requirements, (e.g. load, performance, installation, back-out, and rollback) in the Build Test Plan. The Contractor shall populate its Test Strategy section of the test plan in VA's approved tool within 15 days of the completion of the Build Plan.

At the conclusion of the Build Planning phase, the Contractor shall provide a Build Release Planning Package outlining the prioritized capabilities, estimation of size and timeline for completion.

Deliverables:

- A. Build Plan
- B. ISA/MOUs and SLAs
- C. Build Test Plan
- D. Build Release Planning Package

5.9.3 SPRINT PLANNING

Once build planning is completed and accepted, the Contractor shall initiate Sprint Planning for each Sprint of the release. All activities scheduled in each sprint and backlog shall be captured and have status showing all work items, changes, impediments, and retrospectives. All data and artifacts in VA Approved Tool shall be fully linked to requirements data and test data.

The Contractor shall:

- Initiate and participate in a Sprint Planning Meeting, at the beginning of each sprint. The Contractor shall update the Sprint Plan in the VA Approved Tool after the Sprint Planning.
- Support, coordinate and provide input for the Sprint Acceptance Criteria in VA Approved Tool. The Sprint Acceptance Criteria shall be coordinated and approved for every sprint. This task shall result in an Approved Sprint Plan.
- In collaboration with the Business/Product Owner, take the approved prioritized items identified from build planning and create and prioritize the sprint backlog.
- Identify user stories and tasks to be completed within the sprint, the agreement of acceptance criteria for the sprint, and readiness to begin sprint.
- Conduct a sprint design to understand what problem needs to be solved for each user story, understand critical business functions, test initial concepts,

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

and look for objective feedback. Methods of design could include mock-ups, storyboards, and rapid prototyping.

- In collaboration with key VA Stakeholders, determine the testing events required for the Sprint.

Deliverables:

A. Sprint Plan

5.9.4 SPRINT EXECUTION

All activities executed in each sprint and backlog shall be captured and have status showing all work items, changes, risks, issues, impediments, and retrospectives. All data and artifacts in VA Approved Tool shall be fully linked to requirements data and test data.

The Contractor shall:

- Provide a certified Scrum Master to facilitate all ceremonies, ensure VA approved tool is updated daily, enforce scrum framework, track and assist with removing impediments.
- Conduct sprint development including disciplined testing (unit, functional, regression) and reviews as a continuous process, to avoid finding issues at the end of sprint development. Develop the features and capabilities as work items in VA approved tools that were established in the Sprint Plan.
- Develop the features and capabilities as work items in VA Approved Tool that were established in the Sprint Plan.
- Complete sprint configuration including disciplined testing (unit, functional, regression) and reviews as a continuous process, to avoid finding issues at the end of sprint development.
- Initiate and conduct daily scrums (typically 15 minutes) to show the team progress, impediments and daily plans.
- Update the VA Approved Tool daily, to include progress on tasks during sprints, blockers and dependencies.
- Coordinate and support demonstration of the sprint activities with the project team and Users at the end of each sprint. This is termed a Sprint Review and shall result in Customer Acceptance of the Sprint.
- Develop and deliver automated build and automated publishing capabilities to schedule jobs and support continuous integration for every sprint. Automated build tools shall be in compliance with the approved list from the One-VA TRM and code shall be demonstrable and stable enough to be promoted to another environment without issue by evidence of the status of tests and results in the VA approved tool (currently Jira/GitHub).
- The Contractor shall document all activity executed in each sprint and updates to the backlog in Jira/GitHub or VA approved tool including all project artifacts such as work items, changes, risks, issues, impediments, and retrospectives. All data and artifacts in VA approved tool shall be fully linked to requirements data and test data. All project artifacts and source code shall be under change and

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

configuration management as specified by the COR or ACOR/PM using Jira/GitHub or VA approved tool.

- Initiate and facilitate a Sprint Retrospective at the end of the Sprint to capture team performance lessons learned. The Contractor shall provide a Sprint Retrospective Report.

Deliverable:

- A. Sprint Retrospective Report

5.10 APPLICATION PERFORMANCE MONITORING AND ALERTING (OPTIONAL HELM PL PRODUCT/PROJECT)

5.10.1 APPLICATION PERFORMANCE MONITORING (APM)

The Contractor shall provide Application Performance Monitoring (APM) capabilities to ensure the reliability, availability, and performance of HELM PL applications. All APM activities shall comply with VA DevSecOps, Enterprise Operations, and OIT monitoring standards.

The Contractor shall:

- Implement VA Approved Monitoring Tools
Deploy, configure, and maintain TRM approved APM tools to monitor application health, performance, resource utilization, transaction flows, and end user experience.
- Provide Real-Time Monitoring and Alerting
Continuously monitor key performance indicators, latency, error rates, throughput, and capacity utilization, and configure automated alerts for threshold violations.
- Conduct Performance Analysis
Perform recurring analysis of performance data, establish performance baselines/thresholds, identify bottlenecks or degradation trends, and recommend corrective actions or optimizations as necessary. Provide Performance Baseline and Threshold Documentation.
- Support Incident Management and Root Cause Analysis
Use APM telemetry to support identification, diagnosis, and resolution of production incidents in accordance with VA incident management processes. Provide Incident and Root Cause Analysis reports as required.
- Integrate APM with DevSecOps Pipelines
Incorporate APM monitoring and performance validation into CI/CD pipelines to support continuous testing, quality gates, and release readiness.
- Support Capacity and Scalability Planning
Provide analysis and forecasting data to support infrastructure scaling and capacity planning for SCM applications.

Deliverables:

- A. Monitor Key Performance Indicators

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- B. Performance Trend Analysis Report
- C. Performance Baseline and Threshold Documentation
- D. Incident and Root Cause Analysis Reports (as required)
- E. Monthly APM Performance Report
- F. Perform Capacity and Scalability Planning

5.10.2 APPLICATION MONITORING PLAN (AMP)

As part of HELM Development and Operations, the Contractor shall utilize Application Performance Monitoring strategies for application health and performance and develop product performance metrics that shall be monitored throughout the contract.

The Contractor shall provide an Application Monitoring Plan (AMP) that defines how metrics shall be monitored throughout the performance of the requirements, including the automated testing tools and automated Service Level is (SLA) testing scripts that shall be used. The Contractor shall provide the Application Monitoring Plan to the VA PM/COR for review and approval. Upon approval, the Contractor shall implement application monitoring IAW the approved plan and establish an Application Monitoring Dashboard that provides real time performance metrics to all program stakeholders.

The Contractor APM processes shall:

- Ensure that custom software components can be instrumented to support a VA approved performance monitoring standard (e.g. Open Tracing)
- Produce and maintain documentation describing data flow through the application, focusing on how and when the application passes/accepts data to/from other systems or end users.
- Ensure that all workflows and actions identified during the HCD process are distinctly mapped/measured in the monitoring environment.
- Define and describe how monitoring of the system, network, application, database logs, and performance metrics via VA approved VAEC/Cloud Service Provider (CSP) monitoring tools shall occur (and be executed) and ensure that code and logic changes are accurately reflected in the monitoring tools.
- Write and monitor synthetic monitoring scripts for VA infrastructure and applications.
- Perform postmortems of any outages occurred, including root cause analysis and steps to prevent future outages and provide Postmortem Reports accordingly.

The Contractor shall document in the Monthly Status Report performance metrics including but not limited to number of issues reported, problem type identification, % resolved, time for resolution, priority, severity, etc. as agreed to with the PM/COR. The Contractor shall provide a Response Time Monitoring Report, appended to the Monthly Status Report, that provides response time frames at the 50th, 75th, 95th, and 99th percentiles for each health product.

Deliverables:

- A. Application Monitoring Plan

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- B. Application Monitoring Dashboard
- C. Postmortem Reports
- D. Response Time Monitoring Report (appended to the Monthly Status Report)

5.10.3 DECOMMISSIONING SUPPORT

The Contractor shall provide an approach and plan for decommissioning VA legacy systems being replaced by “to-be” systems. The approach should encompass identifying, gathering, and analyzing representative system-specific data to understand the conditions, parameters, limitations, and other factors that shall drive decommission plans. Topics of interest and data sources may include, but not be limited to, the following:

- Users/user communities
- System features including how they are used to support user community business operations and what gaps exist between legacy systems and the “to-be” systems
- Data movement within legacy systems, across integrated solutions, and downstream to reporting tools
- Data retention requirements
- Regulations and policies
- Legal review of Course Of Action (COA) for records retention purposes
- Contractual support and implications for, or issues concerning, reduced or eliminated contractual support requirements
- System integrations
- Architecture

5.10.3.1 ALTERNATE SOLUTIONS FOR DECOMMISSIONING SYSTEMS

The Contractor shall identify alternate solutions for decommissioning each legacy system. Depending on the data gathered, this may include a series of interim or transitional steps leading towards the long-term solution. Based on the alternatives identified, the Contractor shall perform an analysis of alternatives for VA leadership to select as the long-term enterprise approach.

Based on scope of issues discovered, determine alternatives to facilitate shut down (e.g., maintain legacy systems until retention period ends; develop archive systems; consolidate legacy systems’ data in single legacy system instance; rely on Corporate Data Warehouse (CDW), Jira or Confluence archive instance; and others)

The Contractor shall develop a decommissioning analyses document for each legacy system which shall include, but is not limited to:

- System description
- Technical architecture (to include internal and external interfaces)
- Data exchange
- Data retention requirements
- Decommissioning dependencies

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- System support resources
- Decommissioning costs

5.10.3.2 DECOMMISSIONING PLAN

The Contractor shall develop and maintain an iterative Legacy System Decommissioning Plan (for the designated legacy system identifying the approach, steps, and roles and responsibilities for decommissioning each legacy system).

5.10.3.3 TECHNICAL SUPPORT FOR DECOMMISSIONING

Upon approval of a Legacy System Decommissioning Plan, the Contractor shall provide technical support for executing the Plan. Technical Support shall include any migration of data to secure storage, standing up servers for data retention, physically dismantling legacy servers and turning equipment in to be excessed, and modifying/closing user access.

Deliverables:

- A. Analysis of Alternatives for an Enterprise Decommissioning Approach
- B. Legacy Decommissioning Analysis Document
- C. Legacy System Decommissioning Plan

5.11 MIGRATION TO CLOUD ENVIRONMENT & HOSTING SUPPORT (OPTIONAL HELM PL PRODUCT/PROJECT)

The Contractor shall provide comprehensive cloud migration, hosting, and sustainment support to transition HELM PL applications, services, data, and integrations from legacy on premise or hybrid environments into the VAEC or other VA approved cloud environments. The Contractor shall ensure all migrated systems meet VA security, performance, interoperability, and availability requirements.

The Contractor shall perform the following activities:

- **Cloud Architecture and Migration Planning**
 - Develop a Cloud Migration Strategy and Architecture Blueprint that defines target state architectures, cloud service models (IaaS/PaaS/SaaS), data flow, network topology, IAM requirements, and dependencies.

Develop a Cloud Migration Support Plan that defines how the system will be supported during and after migration.

Conduct assessments of existing applications, infrastructure components, and interfaces to determine migration readiness, required refactoring, containerization needs, and performance impacts.

Conduct cloud capacity, resiliency, and cost optimization planning based on VA operational and scalability requirements.

- **Migration Execution and Implementation Support**
 - Build and configure cloud environments, including VPC networking, firewalls,

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

subnets, load balancers, security groups, IAM roles, container orchestration (e.g., Kubernetes), and monitoring frameworks.

- Execute migration activities including data replication, cut-over planning, Domain Name System (DNS) updates, configuration synchronization, and failover testing.
- Re-platform, re-host, re-architect, or retire components as required to achieve target cloud architecture.

- **Cloud Security and Compliance**

- Ensure cloud solutions comply with NIST SP 800-53 REV 5, FedRAMP, VA Directive 6500, VA Zero Trust Architecture (ZTA) principles, IPv6 requirements, and all other VA cybersecurity policies.
- Implement required cloud security controls, including encryption in transit and at rest, boundary protection, audit logging, identity federation, and secrets management.
- Support ATO updates or new ATO packages for cloud-deployed systems.

- **Cloud Testing and Validation**

- Develop and execute a Cloud Migration Test Plan, including functional, regression, performance, continuity of operations, security, and integration testing.
- Validate connectivity to external dependent systems (e.g., Oracle Health EHR, iFAMS, CDW, VA network services).
- Conduct end to end validation in nonproduction and production environments to ensure functionality after migration.

- **Cloud Hosting Operations and Maintenance (Post Migration Support)**

- Provide hosting support for all HELM systems migrated to the cloud, including continuous monitoring, incident response, patching, backup, disaster recovery, performance tuning, and capacity adjustments.
- Configure and maintain cloud native monitoring and observability tools (e.g., CloudWatch, Azure Monitor, Dynatrace, AppDynamics, APM tools) to ensure application health.
- Maintain continuous integration/continuous deployment (CI/CD) pipelines in cloud based DevSecOps toolchains.

- **Disaster Recover (DR) and Continuity of Operations (COOP)**

- Establish DR/COOP environments with defined RTO/RPO thresholds for each HELM system
- Perform periodic DR failover tests and document results in a Cloud DR Validation Report.
- The Contractor shall provide DR/COOP Plan and test Result

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- **Documentation and Knowledge Transfer**
 - Deliver Cloud Architecture Documentation, Migration Runbooks, Operations Manuals, ATO updates, and cloud configuration baselines.
 - Provide training to VA staff on cloud operations, monitoring, and system administration.

Deliverables:

- A. Cloud Migration Strategy & Architecture Blueprint
- B. Cloud Migration Support Plan
- C. Cloud Migration Test Plan
- D. Cloud Migration Test Summary Report
- E. Updated ATO/A&A Artifacts
- F. Cloud Operations Manual / Runbook
- G. Post Migration Validation Report
- H. DR/COOP Plan and Test Result

5.11.1 VAEC CLOUD HOSTING

The Contractor shall support the migration from the current environment to the VAEC Cloud environment. The Contractor shall coordinate with existing infrastructure POC, and provide technical support for testing, configuration management, and documentation. In addition, the Contractor shall conduct testing and verify application functionality is operating as designed, both during and after the migration.

The Contractor shall:

- Coordinate with the VA Cloud team to develop a clear approach to data migration and replication that minimizes the project production downtime.
- Provide a VAEC Migration Support Plan that identifies the tasks, schedule, as well as the roles and responsibilities for migration.
- Provide a VAEC Migration Test Plan that identifies the Contractor's testing approach, including pass/fail criteria, risks, etc.
- Execute testing in accordance with the approved plan and provide a VAEC Migration Test Summary Report that identifies the tests executed, what tests passed or failed as well as any defects encountered during the migration test.
- Respond to project-related technical questions from either the VAEC or from existing infrastructure POC.
- Validate project is operating as required in all of its production and non-production environments. The Contractor shall support the resolution of migration anomalies.
- Ensure all the development and build tools, as well as interfaces to external systems are operating in their new cloud environments as required.
- Support the validation of the project connectivity (endpoints) including project-dependent systems and interfaces as defined in the System Design Document.

Deliverables:

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

- A. VAEC Migration Support Plan
- B. VAEC Migration Test Plan
- C. VAEC Migration Test Summary Report

5.11.2 EXTERNAL HOSTED APPLICATION

The Contractor shall support the external hosting of a commercially provided application by way of a SaaS delivery mechanism. The Contractor shall coordinate with the SaaS infrastructure POC for the purpose of providing technical support as it pertains to understanding and aligning the SaaS provider's business operation methods with the VA's requirements governing incident management, application testing, dynamic provisioning of virtual computing resources, cybersecurity, data management, privacy management, configuration management, Disaster Recovery & Reconstitution, and system documentation.

5.12 INFRASTRUCTURE AND SECURITY REQUIREMENTS (OPTIONAL HELM PL PRODUCT/PROJECT)

The Contractor shall support the HELM Product Line by understanding and documenting the technical architecture of the information systems that comprise the aforementioned Product Line. As part of this effort, the Contractor shall:

- Understand and document current and future state data flows, networking, cybersecurity, and infrastructure requirements for the successful implementation of new applications.
- Identify and analyze systems targeted for integration and the design and technologies needed to implement them.
- Develop "As-Is" and "To-Be" DoDAF compliant Architecture Models, including architecture diagrams detailing the logical, network, and data flow of the products.
- Ensure that any solution architecture developed aligns with the VA's enterprise strategy, roadmap, and direction.
- Comply with all federal and VA security and privacy requirements, including the development of Assessment and Authorization (A&A) artifacts to obtain and maintain an Authority to Operate (ATO) for all HELM Product Line systems.
- Assess Vulnerability Scanning reports to include documentation within the ATO artifact repository for the reports and assessments.

Deliverables:

- A. As-Is and To-Be Architecture Models
- B. DoDAF compliant Architecture Diagrams
- C. Solution Architecture Package
- D. Vulnerability Scanning Reports and Assessments
- E. Assessment & Authorization (A&A) Artifacts

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

**5.13 ADDITIONAL IMPLEMENTATION SUPPORT (OPTIONAL TASK 3) (T&M)
5.13.1 OPTIONAL TASK – HELM SCM DSO SUPPORT SERVICES (T&M)**

The Contractor shall provide optional support services on a Time and Materials (T&M) basis only when expressly directed by the Government. All T&M work shall be limited to activities authorized under CO approved TO or written Task Directives issued in accordance with the HELM Intake Process. Each T&M effort shall define the scope, Not to Exceed (NTE) ceiling, authorized labor categories, material requirements, PoP, and acceptance criteria.

T&M support shall supplement, and shall not replace or substitute for, work performed under Firm Fixed Price (FFP) contract line items. T&M labor may be utilized only when HELM requires specialized, unplanned, or high complexity SME assistance that cannot be forecasted or reasonably priced under FFP. Such tasks shall include, but are not limited to:

- Data management, system integration, implementation support, and network engineering essential to advancing VA supply chain capabilities.
- Supply chain forecasting, obsolescence analysis, inventory optimization, and risk evaluation.
- Development of technical roadmaps, implementation strategies, and recommendations supporting VA's objectives for a resilient, data driven, and interoperable supply chain.
- Supplemental Sprint team support when requirements exceed existing team capacity or require highly specialized expertise.

The Contractor shall provide advanced DevSecOps, engineering, and product specific technical skillsets consistent with VA's enterprise modernization and digital transformation priorities. T&M services shall include activities that extend beyond planned backlog or development objectives necessary to support Supply Chain Integration and Modernization.

The Contractor shall:

- Track all labor hour usage at the individual level
- Log materials separately from labor
- Ensure T&M work does not overlap or duplicate FFP scope
- Maintain real time visibility of consumed vs. remaining NTE ceiling

The COR/ACOR will review all T&M deliverables and labor usage against defined objectives, TO acceptance criteria, compliance with SDLC and architecture requirements. T&M support shall follow HELM SDLC, DevSecOps, and Product Line Architecture standards to ensure consistency with FFP work. The Government shall provide necessary requirements, system access, and stakeholder coordination. The contractor shall deliver T&M Task Order Work plan, Final Technical Results/SME output, any updated documentation/artifacts as required by Task, and close out report when task is complete.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

Deliverables:

- A. T&M Task Order Work Plan (per task order)
- B. Final Technical Results or SME Output (per task order)
- C. Updated documentation/artifacts as required by task
- D. Closeout Report (summarizing work performed, total cost, hours, remaining funds)

5.14 TRANSITION SUPPORT (OPTIONAL TASK FOUR)

If this optional task is exercised by VA, the Contractor shall provide a plan for 60 days of outgoing transition support for transitioning work from the current contract to a Government entity or to another Contractor. In accordance with the Government-approved plan, the Contractor shall assist the Government in implementing a complete transition from this contract to a new support provider. This shall include formal coordination with Government staff and successor staff and management with documented Transition Plan. It shall also include delivery of copies of all artifacts delivered under this contract, as well as existing policies and procedures, and delivery of baseline metrics and statistics.

This Transition Plan shall include, but is not limited to:

- 1. Coordination with Government representatives.
- 2. Review, evaluation and transition of current support services.
- 3. Transition information of historical data to a new Contractor utilizing Rational or VA approved tool as the repository.
- 4. Transition of Rational/VA approved tool accounts.
- 5. Transfer of all necessary business and/or technical documentation and ensure they are accessible through Rational or VA approved tool.
- 6. Orientation phase and program to introduce Government and Contractor personnel, programs, and users to the Contractor's team, tools, methodologies, and business processes.
- 7. Transfer of GFE and Government Furnished Information, and GFE inventory management assistance.
- 8. Turn-in of all Government keys, ID/access cards, and security codes.

The Contractor shall also produce a list of all assets associated with the project at the time of acceptance of the Final Certification of Software Quality Assurance of assets. This shall be finalized upon full Government acceptance of the asset because documentation and other assets may change based upon the development contractors' remediation of defects effort during Deployment Support. This includes all software assets, specification of support environments, tools; hardware and software licenses, warranties, and maintenance agreements; documentation, and any other assets that must be maintained throughout the asset lifecycle. The finalized asset list shall be delivered as a Certificate of Transition Completion for all assets, which shall be signed by the Development PM and the Receiving Organization to indicate acceptance.

Deliverables:

- A. Transition Plan

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

B. Certificate of Transition Completion

6.0 GENERAL REQUIREMENTS

6.1 ENTERPRISE AND IT FRAMEWORK

6.1.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall comply with the VA OIT Technical Reference Model (VA TRM). Compliance with the VA TRM is achieved by using only technologies and standards that are listed as approved for use in the VA TRM. The Contractor shall provide all necessary information requested by VA to ensure TRM approval is obtained prior to use on VA's network.

6.1.2 ZERO TRUST – VA CRITICAL SECURITY CONTROLS

VA has established minimum mandatory security requirements and requires that any network connected software system or service must meet the VA Critical Security Controls as outlined in the VA Memorandum, "VA Security Controls", <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>. VA Critical Security Controls identify the minimum mandatory requirements that must be implemented across all VA enterprise infrastructure, cloud computing environments, information systems, networks, and specialized devices (medical devices/systems, special-purpose systems, and research scientific computing devices) that process, store, and/or transmit VA data. Effective July 1, 2025, the Contractor shall implement these VA Critical Security Controls, within any network connected software system or service prior to being authorized for use in the VA. This functional requirement is not negotiable, and Plan of Action & Milestones (POAM) shall not be accepted in the event these controls cannot be implemented for new systems. Critical Security Controls are intended to increase VA's security posture and provide security and privacy risk visibility into the VA network and is not a new requirement. The Contractor's failure to maintain these VA Critical Controls after implementation shall result in VA discontinuing the use of the system.

6.1.3 FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)

The Contractor shall ensure Commercial Off-The-Shelf (COTS) product(s), software configuration and customization, and/or new software are Personal Identity Verification (PIV) card-enabled by accepting HSPD-12 PIV credentials using [VA Enterprise Architecture \(EA\)](#), and VA Identity and Access Management (IAM) approved [Enterprise Technology Guidelines \(ETG\)](#). The Contractor shall ensure all Contractor delivered applications and systems comply with the VA Identity, Credential, and Access Management policies and guidelines set forth in Executive Order 14028, VA Handbook 6510 VA Identity and Access Management, VA Handbook 0735 Homeland Security Presidential Directive 12 (HSPD-12) Program, CISA Binding Operational Directive 23-01, and align with the Federal Identity, Credential, and Access Management Roadmap and Implementation Guidance v2.0.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-63-4, VA Handbook 6500, and VA IAM enterprise requirements for direct, assertion-based authentication, and/or trust based authentication, as determined by the ETGs. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV card and/or Common Access Card (CAC), as determined by the business need.

The Contractor shall ensure all Contractor delivered applications and systems conform to the specific Identity and Access Management PIV requirements set forth in the Office of Management and Budget (OMB) Memoranda [M-05-24](#), [M-19-17](#), [M-22-09](#), and NIST Federal Information Processing Standard (FIPS) 201-3. Contractor delivered applications and systems shall be on the FIPS 201 Approved Product List (APL). If the Contractor delivered application and system is not on the APL, the Contractor shall be responsible for taking the application and system through the FIPS 201 Evaluation Program.

The Contractor shall ensure all Contractor delivered applications and systems support:

- Automated provisioning and are able to use enterprise provisioning service.
- Interfacing with VA's Master Person Index (MPI) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
- The VA defined unique identity (Secure Identifier [SEC ID] / Integrated Control Number [ICN]).
- Multiple authenticators for a given identity and authenticators at every Authenticator Assurance Level (AAL) appropriate for the solution.
- Identity proofing for each Identity Assurance Level (IAL) appropriate for the solution.
- Federation for each Federation Assurance Level (FAL) appropriate for the solution, if applicable.
- Two-factor authentication (2FA) through an applicable Technology Guideline as outlined in VA ETG.
- A Security Assertion Markup Language (SAML) implementation if the solution relies on assertion-based authentication. Additional assertion implementations, besides the required SAML assertion, may be provided as long as they are compliant with NIST SP 800-63-4 guidelines.
- Authentication/account binding based on trusted Hypertext Transfer Protocol (HTTP) headers if the solution relies on Trust based authentication.
- Role Based Access Control.
- Auditing and reporting capabilities.
- Compliance with VIEWS 00155984, PIV Logical Access Policy Clarification <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>.

The required Assurance Levels for this specific effort are Identity Assurance Level 3, Authenticator Assurance Level 3, and Federation Assurance Level 3.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

6.1.4 INTERNET PROTOCOL VERSION 6 (IPv6)

The Contractor solution shall support IPv6-Only based upon the memo issued by the Office of Management and Budget (OMB) on November 19, 2020 (<https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf>). Which defines IPv6-only as the state of an operational system or service when IPv4 protocol functions (addressing, packet forwarding) are not in use. The NIST USGv6 profile defines technical requirements for a product to be capable of operating in IPv6-Only environments. IPv6-Only technology, in accordance with the USGv6 Program (<https://www.nist.gov/programs-projects/usgv6-program/usgv6-revision-1>), NIST Special Publication (SP) 500-267B Revision 1 "USGv6 Profile" (<https://doi.org/10.6028/NIST.SP.500-267Br1>), and NIST SP 800-119 "Guidelines for the Secure Deployment of IPv6" (<https://doi.org/10.6028/NIST.SP.800-119>), compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices, applications, and systems shall support all applicable functionality on native IPv6-Only as well as dual stack (IPv6 / IPv4) connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g., web, email, DNS, ISP services, etc.) shall support native IPv6-Only and dual stack (IPv6 / IPv4) users and all internal infrastructure and applications shall support using native IPv6-Only and dual stack (IPv6 / IPv4) for all functionality and operations.

6.1.5 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, "Update to the Trusted Internet Connections (TIC) Initiative" (<https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf>), VA Directive 6513 "Secure External Connections", and shall comply with the TIC 3.0 Core Guidance Documents, including all Volumes and TIC Use Cases, found at the Cybersecurity & Infrastructure Security Agency (CISA) (<https://www.cisa.gov/publication/tic-30-core-guidance-documents>).

6.1.6 STANDARD COMPUTER CONFIGURATION

The Contractor IT end user solution that is developed for use on standard VA computers shall be compatible with and be supported on the standard VA operating system, Windows 11, Edge (Chromium based), and 365 Apps for enterprise. Applications delivered to VA and intended to be deployed to Windows 11 workstations shall be delivered as a signed. Msi package with switches for silent and unattended installation and updates shall be delivered in signed .msp file formats for easy deployment using Microsoft Endpoint Configuration Manager (CM) VA's current desktop application deployment tool. Signing of the software code shall be through a contractor provided certificate that is trusted by VA using a code signing authority such as Verizon/Cybertrust or Symantec/VeriSign. The Contractor shall also ensure and certify that their solution functions as expected when used from a standard VA computer, with non-admin, standard user rights that have been configured using the Defense

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

Information Systems Agency (DISA) Secure Technical Implementation Guide (STIG) specific to the particular client operating system being used.

6.1.7 VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM)

The Contractor shall support VA efforts IAW the Veteran-Focused Integration Process (VIP) Guide and Product Line Management (PLM) Playbook. The major focus of VIP is on Enterprise Oversight, Governance, reporting, and establishing practices that focus on outcomes and continuously delivering sustainable IT capabilities to benefit the Veteran. PLM is a framework that focuses on delivering functional products that provide the highest priority work to customers while delivering simplified, reliable, and practical solutions to the business, medical staff, and our Veterans. The VIP Guide is a companion guide to the PLM Transformation Playbook and can be found at: <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371> and the PLM Transformation Playbook can be found at <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>. VIP and PLM are the authoritative processes that IT projects must follow to ensure development and delivery of IT products.

The VIP Guide provides guidance for transitioning from project-centric to product-centric delivery. The VIP guide applies to all OIT Office of Management and Budget (OMB) reportable products that are required to collect and report costs, schedules, risks, and other valuable information in VA PARS (whether products are procured or developed by VA) and any VA Information Technology project effort in Software Product Management (SPM) and Infrastructure Operations (IO), or their successors, that touch the VA network regardless of IT organizational alignment (whether it spends government funding from VA's Congressional IT Appropriation or any other appropriation).

The PLM Transformation Playbook details how OIT leadership expects Product Lines (PLs) to implement PLM, DevOps, and Lean-Agile principles, methods, practices, and techniques through levels of maturity. The PLM Transformation Playbook applies to all Information Technology (IT) products aligned to PLs in the Software Product Management, Infrastructure Operations and Product Engineering organizations within the OIT organization.

Others outside the referenced groups or organizations may use the VIP Guide and PLM Transformation Playbook for situational awareness as needed.

6.1.8 PROCESS ASSET LIBRARY (PAL)

The Contractor shall perform their duties consistent with the processes defined in the OIT Process Asset Library (PAL). The PAL includes a spectrum of OIT functions and activities, such as project management, operations, service delivery, communications, acquisition, and resource management. PAL serves as an authoritative and informative repository of searchable processes, activities or tasks, roles, artifacts, tools and applicable standards and guides to assist the OIT workforce, Government and Contractor personnel. OIT utilizes PAL processes to ensure compliance with policies

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

and regulations and to meet VA quality standards. The PAL includes the contractor onboarding process consistent with Section 6.2.2 and can be found at [process CONB_ext.docx \(live.com\)](#). The main PAL can be accessed at www.va.gov/process.

6.1.9 AUTHORITATIVE DATA SOURCES

The VA Enterprise Architecture Repository (VEAR) is one component within the overall EA that establishes the common framework for data taxonomy for describing the data architecture used to develop, operate, and maintain enterprise applications. The Contractor shall comply with the department's Authoritative Data Source (ADS) requirement that VA systems, services, and processes throughout the enterprise shall access VA data solely through official VA ADSs where applicable, see below. The Information Classes which compose each ADS are located in the VEAR, in the Data & Information domain. The Contractor shall ensure that all delivered applications and system solutions support:

- Interfacing with VA's Master Person Index (MPI) (formerly the Master Veteran Index (MVI)) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
- Interfacing with Capital Asset Inventory (CAI) to conduct real property record management actions, if the solution relies on real property records data. CAI is the authoritative source for VA real property record management data.
- Interfacing with electronic Contract Management System (eCMS) for access to contract, contract line item, purchase requisition, offering vendor, and solicitation information above the micro-purchase threshold, if the solution relies on procurement data. ECMS is the authoritative source for VA procurement actions data.
- Interfacing with HRSmart Human Resources Information System to conduct personnel action processing, on-boarding, benefits management, and compensation management, if the solution relies on personnel data. HRSmart is the authoritative source for VA personnel information data.
- Interfacing with VA Profile to access personal contact information, if the solution relies on VA Veteran personal contact information data. VA Profile is the authoritative source for VA Veteran Personal Contact Data.
- Interfacing with VA/Department of Defense (DoD) Identity Repository (VADIR) for determining eligibility for VA benefits under Title 38, if the solution relies on qualifying active-duty military service data. VADIR is the authoritative source for qualifying active-duty military service in VA.
- Interfacing with VA Systems Inventory (VASI) to access VA systems information, if the solution relies on VA system information. VASI is the authoritative source for VA Information Technology systems.
- Interfacing with Enterprise Mission Assurance Support Service (eMASS) to access the historical Authority to Operate (ATO) status of all VA Information Systems prior to migrating to ServiceNow Continuous Authorization and Monitoring (SNOWCAM) until it is determined the migration is completed and eMASS is sunset. eMASS contains the historical ATO status of all VA

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

Information Systems prior to September 30, 2025, with all status provided through SNowCAM once migration is completed.

6.1.10 SOCIAL SECURITY NUMBER (SSN) REDUCTION

The Contractor solution shall support the Social Security Number (SSN) Fraud Prevention Act (FPA) of 2017 which prohibits the inclusion of SSNs on any document sent by mail. The Contractor support shall also be performed in accordance with Section 240 of the Consolidated Appropriations Act (CAA) 2018, enacted March 23, 2018, which mandates VA to discontinue using SSNs to identify individuals in all VA information systems as the Primary Identifier. The Contractor shall ensure that any new IT solution discontinues the use of SSN as the Primary Identifier to replace the SSN with the ICN in all VA information systems for all individuals. The Contractor shall ensure that all Contractor delivered applications and systems integrate with the VA MPI for identity traits to include the use of the ICN as the Primary Identifier. The Contractor solution may only use a Social Security Number to identify an individual in an information system if and only if the use of such number is required to obtain information VA requires from an information system that is not under the jurisdiction of VA.

6.1.11 GENERATIVE ARTIFICIAL INTELLIGENCE REQUIREMENTS

If Artificial Intelligence (AI) is part of the Contractor system/solution, the Contractor shall be in compliance with E.O. 13960 and 14319, OMB Memorandums M-25-21, M-25-22, and M-26-04, and VA Directive and Handbook 6500 to support VA in trustworthy, secure, responsible, accountable, Truth Seeking, and Ideologically Neutral AI innovation.

No web-based, publicly available generative AI service has been approved for use with VA-sensitive data including, but not limited to OpenAI's ChatGPT, Microsoft's Copilot, Google's Gemini, and Anthropic's Claude. No PII, protected health information (PHI), or VA-sensitive data should be entered into these unapproved services. The entire definition of VA Sensitive Data can be found at 38 U.S.C. § 5727 (23). The Contractor shall protect VA Sensitive data from unauthorized disclosure or use, and from being used to train or improve the functionality of the vendor's commercial offerings without express permission from VA. Only VA-hosted instances of generative AI services may be approved for use with VA-sensitive data.

The Contractor shall deliver the services, technical data, configurations, models, weights, documentation or other information, including source code, developed during contract performance. The Contractor, in collaboration with VA, must evaluate the output of any AI tool for accuracy prior to using the output in VA efforts. All data, including models, weights, algorithms, and outputs generated using either Government-furnished data or data first developed under this contract shall be the property of the Government with unlimited rights as defined by FAR 52.227-14. The Contractor shall also deliver any custom-developed code developed with AI methodologies in accordance with the SHARE IT Act, if applicable. VA shall also retain unlimited rights to

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

any improvements to that data, including the continued design, development, testing, and operation of AI systems and/or systems utilizing AI.

The Contractor shall ensure that all AI Systems, including Large Language Models (LLM), whether standalone LLMs or integrated into broader software platforms, procured under this effort and/or used in performance of this contract complies with the Unbiased AI Principles as defined in Executive Order 14319 and OMB Memorandum M-26-04, e.g. Truth Seeking and Ideologically Neutral, as applicable to the intended use of the system.

The Contractor shall ensure that AI System/LLM generated outputs are truthful in responding to user prompts seeking factual information or analysis, prioritize historical accuracy, scientific inquiry, and objectivity, as well as acknowledge uncertainty where reliable information is incomplete or contradictory and do not fabricate, hallucinate, or present unverifiable information as fact.

The Contractor shall ensure that LLMs and AI outputs are neutral, nonpartisan tools that do not manipulate responses in favor of ideological dogmas such as Diversity, Equity, and Inclusion (DEI). The Contractor shall ensure that the LLMs, including the AI System, are not intentionally encoded with partisan or ideological judgments within an AI System's/LLM's outputs unless those judgments are prompted by or otherwise readily accessible to the end user.

Compliance with the AI requirements of this contract, including adherence to the Unbiased AI Principles, Truth-Seeking and Ideological Neutrality requirements, disclosure obligations, monitoring and reporting requirements, and corrective action responsibilities, is a material condition of eligibility for payment and continued performance. In accordance with OMB Memorandum M-26-04, failure to comply with these requirements, or refusal to take timely and appropriate corrective action to remedy identified noncompliance, may constitute a material breach of contract and may result in remedies consistent with the terms of the contract and applicable law including but not limited to withholding of payment, termination for cause/default, or other appropriate contractual remedies, as determined by the Contracting Officer.

All AI for delivery and/or use in performance of the contract shall adhere to the VA *Trustworthy AI Framework*, available at <https://department.va.gov/ai/trustworthy/>. Once the Contractor has obtained CO authorization to use specific AI in contract performance, the Contractor shall provide the COR a signed Statement of Attestation prior to AI implementation as identified in the Artificial Intelligence in VA Contracts clause, to include its associated list of AI being used in contract performance.

Deliverable:

- A. Statement of Attestation

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

**6.1.11.1 AI SYSTEM/LLM DEVELOPMENT AND OPERATION
DOCUMENTATION REQUIREMENTS**

To enable Government continued assessment of compliance with Trustworthy AI requirements and both Unbiased AI Principles, Truth-seeking and Ideological Neutrality, in accordance with OMB M-26-04, the Contractor shall provide AI System/LLM Development and Operation Documentation Package to include, at a minimum:

1. Acceptable Use Policy

The Contractor shall provide an Acceptable Use Policy document governing its AI operation that characterizes and differentiates appropriate and inappropriate use of their product offering

2. Model Cards, System Cards and/or Data Cards

The Contractor shall provide documentation describing essential information about the model, system, and or data as it relates to the AI/LLM product offering. The documentation shall address summaries of training process, identified risks and mitigations, and model evaluation scores on LLM benchmarks at a minimum, where appropriate

3. End User Resources

The Contractor shall provide documentation to include product tutorials, developer guides, and/or other tools to assist VA in ensuring proper use of the AI/LLM to maximize utility

4. Mechanism for End User Feedback

The Contractor shall provide documentation describing the mechanism employed to provide feedback to the Offeror on outputs identified that violate the Unbiased AI Principles. This may be satisfied by a general inbox, specific Point of Contact, or similar feedback mechanism.

5. Pre-Training and Post-Training Activities of the AI System/LLM

The Contractor shall provide documentation of Pre-Training and Post Training Activity that provides details on:

- a. Actions taken that impact the factuality and grounding of AI System/LLM outputs
- b. System-level prompts that provide natural language instructions to the model specifying guidelines on responding to user-generated queries, to include how a model responds when reliable information is incomplete, contradictory, or subject to individual interpretation
- c. The type of outputs restricted via content moderation and safety filters
- d. The use of red teaming as a means of continuously assessing the model to protect against incidents of bias in generated output.
- e. Training or development, if any, that occurred outside the United States, to include the type of activity and the country in which it occurred.
- f. Any modifications or configurations undertaken to comply with any regulation from a government other than the U.S. Federal Government.

6. Model Evaluation Results and Methodologies

The Contractor shall provide documentation describing the Evaluation Results of bias evaluations conducted by the Vendor to include the methodology for performing such tests (e.g., testing prompt pairs for politically oriented topics).

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

The documentation shall also include Benchmark scoring results measuring the model's bias, helpfulness, honesty, or accuracy when provided with ambiguous versus straightforward questions. (Including any benchmarks comparing performance across multiple languages, where applicable).

7. Description of Enterprise-Level Controls

The Contractor shall provide documentation describing the Enterprise Governance tools and controls, such as:

- a. Customizable system instructions that are additive to a base model's system prompts or content generation filters.
- b. Product features that require a model to cite sources of its outputs or otherwise provide visibility into the provenance of the model's outputs.
- c. AI System/LLM model evaluation tools that enable comparisons either between a model's outputs, or across various models.

8. Third Party Modification Disclosure

The Contractor shall disclose of any additional controls to modify an AI Model's/LLM's output applied by the Contractor if the Contractor is not a direct developer of the LLM (e.g., classifiers, system prompts, fine-tuning, content moderation and filters, etc.)

Deliverable:

- A. AI System/LLM Development and Operation Documentation Package

6.1.11.2 MONITORING, REPORTING, AND CORRECTIVE ACTION

The Contractor shall develop and implement a Compliance Monitoring and Reporting Plan supporting ongoing monitoring processes to evaluate AI outputs for compliance with Trustworthy AI and Unbiased AI principles. This plan shall include the mechanism for authorized users to provide end user feedback to report suspected violations of Truth-Seeking or Ideological Neutrality requirements.

The Contractor shall notify the COR within 10 business days of identifying any material deviation from these principles and shall submit a written Corrective Action Plan describing mitigation steps, responsible parties, and timelines. Any material deviation, corrective action taken, and results shall be detailed in the **<Weekly or Monthly>** Progress Reports.

Deliverable:

- A. Compliance Monitoring and Reporting Plan
- B. Corrective Action Plan

6.1.11.3 AI MODEL UPDATES AND CHANGE DISCLOSURES

The Contractor, in an AI Model/LLM Change Disclosure, shall notify the Government throughout the PoP in advance of any material changes to AI models, including new AI enhancements, features and/or components, controls, retraining, classifiers, system prompts, fine-tuning, content moderation, filters, version replacement, or architectural changes, that could reasonably affect compliance with Trustworthy AI or Unbiased AI

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

principles. Updated documentation shall be provided to VA for VA approval prior to implementation of such changes.

Deliverable:

A. AI Model/LLM Change Disclosure

**6.1.12 SOURCE CODE HARMONIZATION AND REUSE IN INFORMATION
TECHNOLOGY (SHARE IT Act)**

6.2 SECURITY AND PRIVACY REQUIREMENTS

It has been determined that protected health information may be disclosed or accessed, and a signed Business Associate Agreement (BAA) shall be required. The Contractor shall adhere to the requirements set forth within the BAA, referenced in Section D of the contract, and shall comply with VA Directive 6066.

6.2.1 POSITION/TASK RISK DESIGNATION LEVEL(S)

In accordance with VA Handbook 0710, Personnel Vetting Program, the position sensitivity and the level of background investigation commensurate with the required level of access for the following tasks within the PWS are:

Position Sensitivity and Background Investigation Requirements by Task
TBD

Task Number	Tier1 / Low Risk	Tier 2 / Moderate Risk	Tier 4 / High Risk
5.1	☐	☐	☐
5.2	☐	☐	☐
5.3	☐	☐	☐
5.4	☐	☐	☐
5.5	☐	☐	☐
5.6	☐	☐	☐
5.7	☐	☐	☐
5.8	☐	☐	☐
5.9	☐	☐	☐
5.10	☐	☐	☐
5.11	☐	☐	☐
5.12	☐	☐	☐
5.13	☐	☐	☐
5.14	☐	☐	☐
5.15	☐	☐	☐
5.16	☐	☐	☐

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

Task Number	Tier1 / Low Risk	Tier 2 / Moderate Risk	Tier 4 / High Risk
5.17	☐	☐	☐
5.18	☐	☐	☐
5.19	☐	☐	☐

The Tasks identified above and the resulting Position Sensitivity and Background Investigation requirements identify, in effect, the Background Investigation requirements for Contractor individuals, based upon the tasks the particular Contractor individual shall be working. The submitted Contractor Staff Roster must indicate the required Background Investigation Level for each Contractor individual based upon the tasks the Contractor individual shall be working, in accordance with their submitted proposal.

6.2.2 CONTRACTOR PERSONNEL SECURITY REQUIREMENTS

Contractor Responsibilities:

- The Contractor shall prescreen all personnel requiring access to the computer systems to ensure they maintain the appropriate Background Investigation, and are able to read, write, speak, and understand the English language.
- Within 3 business days after award, the Contractor shall provide a roster of Contractor and Subcontractor employees to the COR to begin their background investigations in accordance with the PAL template artifact. The Contractor Staff Roster shall contain the Contractor's Full Name, Date of Birth, Place of Birth, individual background investigation level requirement (based upon Section 6.2 Tasks), etc. The Contractor shall submit full Social Security Numbers either within the Contractor Staff Roster or under separate cover to the COR. The Contractor Staff Roster shall be updated and provided to VA within 1 day of any changes in employee status, training certification completion status, Background Investigation level status, additions/removal of employees, etc. throughout the Period of Performance. The Contractor Staff Roster shall remain a historical document indicating all past information and the Contractor shall indicate in the Comment field, employees no longer supporting this contract. The preferred method to send the Contractor Staff Roster or Social Security Number is by encrypted e-mail. If unable to send encrypted e-mail, other methods which comply with FIPS 140-2 (or its successor) are to encrypt the file, use a secure fax, or use a traceable mail service. (Note that by September 22, 2026, all FIPS 140-2 certificate validations shall be placed on the Historical List. See FIPS Transition Effort Timeline for more details: <https://csrc.nist.gov/projects/fips-140-3-transition-effort#schedule>)
- a. The Contractor should coordinate with the location of the nearest VA fingerprinting office through the COR. Only electronic fingerprints are authorized. The Contractor shall bring their completed Personnel Security Adjudication Center (PSAC) Fingerprint request form with them (see paragraph d.4. below) when getting fingerprints taken.

Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946

- The Contractor shall ensure the following required forms are submitted to the COR within 5 days after contract award:
 - Optional Form 306
 - Self-Certification of Continuous Service
 - VA Form 0710
 - Completed PSAC Fingerprint Request Form
- b. The Contractor personnel shall submit all required information related to their background investigations (completion of the investigation documents (SF85, SF85P, or SF 86) utilizing Defense Counterintelligence and Security Agency (DCSA) National Background Investigation Services (NBIS) Electronic Application (eAPP) (formerly e-QIP) after receiving an email notification from the PSAC.
- c. The Contractor employee shall certify and release the eAPP document, print, and sign the signature pages, and send them encrypted to the COR for electronic submission to the PSAC. These documents shall be submitted to the COR within 3 business days of receipt of the eAPP notification email. (Note: DCSA is moving towards a “click to sign” process. If click to sign is used, the Contractor employee should notify the COR within 3 business days that documents were signed via eAPP).
- The Contractor shall be responsible for the actions of all personnel provided to work for VA under this contract. In the event that damages arise from work performed by Contractor provided personnel, under the auspices of this contract, the Contractor shall be responsible for all resources necessary to remedy the incident.
- d. A Contractor may be granted unescorted access to VA facilities and/or access to VA Information Technology resources (network and/or protected data) with a favorably adjudicated Special Agreement Check (SAC), completed training delineated in VA Handbook 6500.6 (Appendix C, Section 4), signed “Contractor Rules of Behavior”, and with a valid, operational Personal Identity Verification (PIV) credential for PIV-only logical access to VA’s network. A PIV card credential can be issued once your SAC has been favorably adjudicated and your background investigation has been scheduled by DCSA. However, the Contractor shall be responsible for the actions of the Contractor personnel they provide to perform work for VA. The investigative history for Contractor personnel working under this contract must be maintained in the database of DCSA.
- The Contractor, when notified of an unfavorably adjudicated background investigation on a Contractor employee as determined by the Government, shall withdraw the employee from consideration in working under the contract.
- Failure to comply with the Contractor personnel security investigative requirements may result in loss of physical and/or logical access to VA facilities and systems by Contractor and Subcontractor employees and/or termination of the contract for default.
- PIV Credential Holders must follow all HSPD-12 policies and procedures as well as use and protect their assigned identity credentials in accordance with VA

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

policies and procedures, displaying their badges at all times, and returning the identity credentials upon termination of their relationship with VA.

Deliverable:

A. Contractor Staff Roster

6.3 METHOD AND DISTRIBUTION OF DELIVERABLES

The Contractor shall deliver documentation in electronic format, unless otherwise directed in Section B of the solicitation/contract. Acceptable electronic media include Microsoft 365 suite, MS Word, MS Excel, MS PowerPoint, MS Project, MS Access, MS Visio, AutoCAD, and Adobe Postscript Data Format (PDF).

6.4 PERFORMANCE METRICS

The table below defines the Performance Standards and Acceptable Levels of Performance associated with this effort.

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

Performance Objective	Performance Standard	Acceptable Levels of Performance
A. Technical / Quality of Product or Service	1. Demonstrates understanding of requirements 2. Efficient and effective in meeting requirements 3. Meets technical needs and mission requirements 4. Provides quality services/products 5. Incorporates "ease of use" Human Centered Design principles in any software developed.	Satisfactory or higher
B. Project Milestones and Schedule	1. Established milestones and project dates are met 2. Products completed, reviewed, delivered in accordance with the established schedule 3. Notifies customer in advance of potential problems	Satisfactory or higher
C. Cost & Staffing	1. Currency of expertise and staffing levels appropriate to perform tasks required 2. Personnel possess necessary knowledge, skills, and abilities to perform tasks	Satisfactory or higher
D. Management	1. Integration and coordination of all activities to execute effort	Satisfactory or higher

The COR shall utilize a Quality Assurance Surveillance Plan (QASP) throughout the life of the contract to ensure that the Contractor is performing the services required by this PWS in an acceptable level of performance. The Government reserves the right to alter or change the surveillance methods in the QASP at its own discretion. A Performance Based Service Assessment shall be used by the COR in accordance with the QASP to assess Contractor performance.

6.5 FACILITY/RESOURCE PROVISIONS

The Government shall provide office space, telephone service and system access when authorized contract staff work at a Government location as required in order to accomplish the Tasks associated with this PWS. All procedural guides, reference

Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946

materials, and program documentation for the project and other Government applications shall also be provided on the as-needed basis.

The Contractor shall request other Government documentation deemed pertinent to the work accomplishment directly from the Government officials with whom the Contractor has contact. The Contractor shall consider the COR as the final source for needed Government documentation when the Contractor fails to secure the documents by other means. The Contractor is expected to use common knowledge and resourcefulness in securing all other reference materials, standard industry publications, and related materials that are pertinent to the work.

VA may provide remote access to VA specific systems/network in accordance with VA Handbook 6500, which requires the use of a VA approved method to connect external equipment/systems to VA's network. Citrix Access Gateway (CAG) and now the Azure Virtual Desktop (AVD) (as VA is currently transitioning from CAG to the AVD), are the current and only VA approved methods for remote access users when using or manipulating VA information for official VA Business. VA permits CAG remote access through approved Personally Owned Equipment (POE) and Other Equipment (OE) provided the equipment meets all applicable 6500 Handbook requirements for POE/OE. All of the security controls required for Government furnished equipment (GFE) must be utilized in approved POE or OE. The Contractor shall provide proof to the COR for review and approval that their POE or OE meets the VA Handbook 6500 requirements and VA Handbook 6500.6 Appendix C, herein incorporated as Addendum B, before use. CAG authorized users shall not be permitted to copy, print, or save any VA information accessed via CAG at any time. VA prohibits remote access to VA's network from non-North Atlantic Treaty Organization (NATO) countries. The exception to this is countries where VA has approved operations established (e.g. Philippines and South Korea). Exceptions are determined by the COR in coordination with the Information System Security Officer (ISSO) and Privacy Officer (PO).

This remote access may provide access to VA specific software such as Veterans Health Information System and Technology Architecture (VistA), ClearQuest, PAL, Primavera, and Remedy, including appropriate seat management and user licenses, depending upon the level of access granted. The Contractor shall utilize government-provided software development and test accounts, documents, and requirements repositories, etc. as required for the development, storage, maintenance, and delivery of products within the scope of this effort. All VA sensitive information shall be protected at all times in accordance with VA Handbook 6500, local security field office System Security Plans (SSP's) and Authority to Operate (ATO)'s for all systems/LAN's accessed while performing the tasks detailed in this PWS. The Contractor shall ensure all work is performed in countries deemed not to pose a significant security risk. For detailed Security and Privacy Requirements (additional requirements of the contract consolidated into an addendum for easy reference) refer to ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED and ADDENDUM B - VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

6.6 GOVERNMENT FURNISHED PROPERTY

The Government has multiple remote access solutions available to include CAG, AVD, Site-to-Site Virtual Private Network (VPN), and RESCUE VPN.

The Government's issuance of Government Furnished Equipment (GFE) is limited to Contractor personnel requiring direct access to the network to: development environments; install, configure and run Technical Reference Model (TRM) approved software and tools (e.g., Oracle, Fortify, Eclipse, SoapUI, WebLogic, LoadRunner); upload/download/ manipulate code, run scripts, and apply patches; configure and change system settings; check logs, troubleshoot/debug, and test/QA.

When necessary, the Government shall refurnish desktops or laptops, for use by the Contractor to access VA networks, systems, or applications to meet the requirements of this PWS. The overarching goal is to determine the most cost-effective approach to providing needed access to the VA environment coupled with the need to ensure proper Change Management principles are followed. Contractor personnel shall adhere to all VA system access requirements for on-site and remote users in accordance with VA standards, local security regulations, policies, and rules of behavior. GFE shall be approved by the COR and Program Manager on a case-by-case basis prior to issuance.

Based upon the Government assessment of remote access solutions and requirements of this effort, the Government estimates the following GFE shall be required by this effort:

1. **75 Standard Laptops**
2. **150 Performance Laptops**

The Government shall not provide IT accessories including but not limited to Mobile Wi-Fi hotspots/wireless access points, additional or specialized keyboards or mice, laptop bags, extra charging cables, extra Personal Identity Verification card readers, peripheral devices, or additional Random Access Memory (RAM). The Contractor is responsible for providing these types of IT accessories in support of this effort as necessary and any VA installation required for these IT accessories shall be coordinated with the COR.

For migration to the VAEC, the Government shall furnish Cloud capacity in and connectivity to the VAEC environments, VA Enterprise Cloud Operational Tools (VAECOT) comprised of a suite of COTS cloud management tools as identified in the VAEC Technical Reference Guide, and Enterprise Development Environment (EDE) and Tools as identified in the VAEC Technical Reference Guide.

Additionally, the Contractor shall provide a status of all reportable GFE as part of the **Monthly** Status Report as required by PWS paragraph 5.1. For purposes of this report, reportable GFE includes equipment that is furnished by the Government as tangible "personal" property which the Contractor takes possession of, physically leaves a

Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946

Government facility, and needs to be returned the end of Contractor performance. The following information shall be provided for each piece of GFE:

- Name of Contractor employee assigned to the GFE
- Type of Equipment (Make and Model)
- Tracking Number/Serial Number
- VA Bar Code
- Location
- Value
- Total Value of Equipment
- Anticipated Transfer Date to Government
- Anticipated Transfer Location

DRAFT

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED

A1.0 Cyber and Information Security Requirements for VA IT Services

The Contractor shall ensure adequate LAN/Internet, data, information, and system security in accordance with VA standard operating procedures and standard PWS language, conditions, laws, and regulations. The Contractor's firewall and web server shall meet or exceed VA minimum requirements for security. All VA data shall be protected behind an approved firewall. Any security violations or attempted violations shall be reported to the VA Program Manager and VA Information Security Officer as soon as possible. The Contractor shall follow all applicable VA policies and procedures governing information security, especially those that pertain to assessment and authorization and continuous monitoring.

Contractor supplied equipment, PCs of all types, equipment with hard drives, etc. for contract services must meet all security requirements that apply to Government Furnished Equipment (GFE) and Government Owned Equipment (GOE). Security Requirements include: a) VA Approved Encryption Software must be installed on all laptops or mobile devices before being placed into operation, b) Bluetooth equipped devices are prohibited within VA; Bluetooth must be permanently disabled or removed from the device, unless the connection uses FIPS 140-2 (or its successor) validated encryption, c) VA approved anti-virus and firewall software, d) Equipment must meet all VA sanitization requirements and procedures before disposal. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems.

Each documented initiative under this contract incorporates VA Handbook 6500.6, "Contract Security," March 12, 2010 (Appendix C updated April 22, 2024) by reference as though fully set forth therein. The VA Handbook 6500.6, "Contract Security" shall also be included in every related agreement, contract, or order. The VA Handbook 6500.6, Appendix C, is included in this document as Addendum B.

Training requirements: The Contractor shall complete all mandatory training courses on the current VA training site, the VA Talent Management System (TMS) 2.0, and shall be tracked therein. The TMS 2.0 may be accessed at <https://www.tms.va.gov/SecureAuth35/>. If you do not have a TMS 2.0 profile, go to <https://www.tms.va.gov/SecureAuth35/> and click on the "Create New User" link on the TMS 2.0 to gain access.

Contractor employees shall complete a VA Systems Access Agreement if they are provided access privileges as an authorized user of the computer system of VA.

A2.0 VA Enterprise Architecture Compliance

The applications, supplies, and services furnished under this contract must comply with VA Enterprise Architecture (EA), available at <http://www.ea.oit.va.gov/index.asp> in force at the time of issuance of this contract, including the Program Management Plan and

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

VA's rules, standards, and guidelines in the Technical Reference Model/Standards Profile (TRMSP). VA reserves the right to assess contract deliverables for EA compliance prior to acceptance.

A2.1. VA Internet and Intranet Standards

The Contractor shall adhere to and comply with VA Directive 6102 and VA's Web Governance if the Contractor's work includes building and maintaining VA's digital presence. This pertains, but is not limited to: websites, social media, creating announcements; collecting information; databases to be accessed, graphics and links to external sites.

Internet/Intranet Services Directive 6102 is posted at (copy and paste the following URL to browser): https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1056&FType=2

VA Web Governance website can be found at [Home - VA Web Governance](#).

A3.0 Notice of the Federal Accessibility Law Affecting All Information and Communication Technology (ICT) Procurements (Section 508)

On January 18, 2017, the Access Board issued a final rule that updated accessibility requirements covered by Section 508 and refreshed guidelines for telecommunications equipment subject to Section 255 of the Communications Act. The final rule went into effect on January 18, 2018. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

A3.1. Section 508 – Information and Communication Technology (ICT) Standards

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: [Revised 508 Standards and 255 Guidelines \(access-board.gov\)](#). A single PDF file version of the Revised Section 508 Standards and 255 Guidelines shall be supplied upon request or can be obtained from the Access Board website. Federal agencies must comply with the Rehabilitation Act of 1973, as amended.

The Contractor shall comply with "508 Chapter 2: Scoping Requirements" for all electronic ICT and content delivered under this contract. Specifically, as appropriate for the technology and its functionality, the Contractor shall comply with the technical standards marked here:

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria
- ☒ E206 Hardware Requirements
- ☒ E207 Software Requirements

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

☒ E208 Support Documentation and Services Requirements

A3.2. Compatibility with Assistive Technology

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

A3.3. Acceptance and Acceptance Testing

Deliverables resulting from this solicitation shall be accepted based in part on satisfaction of Section 508 Chapter 2: Scoping requirements standards identified above.

The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

A4.0 Physical Security & Safety Requirements:

The Contractor and their personnel shall follow all VA policies, standard operating procedures, applicable laws and regulations while on VA property. Violations of VA regulations and policies may result in citation and disciplinary measures for persons violating the law.

- The Contractor and their personnel shall wear visible identification at all times while they are on the premises.
- VA does not provide parking spaces at the work site; the Contractor must obtain parking at the work site if needed. It is the responsibility of the Contractor to park in the appropriate designated parking areas. VA shall not invalidate or make reimbursement for parking violations of the Contractor under any conditions.
- Smoking is prohibited inside/outside any building other than the designated smoking areas.
- Possession of weapons is prohibited.
- The Contractor shall obtain all necessary licenses and/or permits required to perform the work, with the exception of software licenses that need to be procured from a Contractor or vendor in accordance with the requirements document. The Contractor shall take all reasonable precautions necessary to protect persons and property from injury or damage during the performance of this contract.

A5.0 Confidentiality and Non-Disclosure

The Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations.

The Contractor may have access to Protected Health Information (PHI) and Electronic Protected Health Information (ePHI) that is subject to protection under the regulations

Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946

issued by the Department of Health and Human Services, as mandated by the Health Insurance Portability and Accountability Act of 1996 (HIPAA); 45 CFR Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information ("Privacy Rule"); and 45 CFR Parts 160 and 164, Subparts A and C, the Security Standard ("Security Rule"). Pursuant to the Privacy and Security Rules, the Contractor must agree in writing to certain mandatory provisions regarding the use and disclosure of PHI and ePHI.

- The Contractor shall have access to some privileged and confidential materials of VA. These printed and electronic documents are for internal use only, are not to be copied or released without permission, and remain the sole property of VA. Some of these materials are protected by the Privacy Act of 1974 (revised by PL 93-5791) and Title 38. Unauthorized disclosure of Privacy Act or Title 38 covered materials is a criminal offense.
- The VA CO shall be the sole authorized official to release in writing, any data, draft deliverables, final deliverables, or any other written or printed materials pertaining to this contract. The Contractor shall release no information. Any request for information relating to this contract presented to the Contractor shall be submitted to the VA CO for response.
- Contractor personnel recognize that in the performance of this effort, Contractor personnel may receive or have access to sensitive information, including information provided on a proprietary basis by carriers, equipment manufacturers and other private or public entities. Contractor personnel agree to safeguard such information and use the information exclusively in the performance of this contract. Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations as enumerated in this section and elsewhere in this Contract and its subparts and appendices.
- Contractor shall limit access to the minimum number of personnel necessary for contract performance for all information considered sensitive or proprietary in nature. If the Contractor is uncertain of the sensitivity of any information obtained during the performance this contract, the Contractor has a responsibility to ask the VA CO.
- Contractor shall train all of their employees involved in the performance of this contract on their roles and responsibilities for proper handling and nondisclosure of sensitive VA or proprietary information. Contractor personnel shall not engage in any other action, venture or employment wherein sensitive information shall be used for the profit of any party other than those furnishing the information. The sensitive information transferred, generated, transmitted, or stored herein is for VA benefit and ownership alone.
- Contractor shall maintain physical security at all facilities housing the activities performed under this contract, including any Contractor facilities according to VA-approved guidelines and directives. The Contractor shall ensure that security procedures are defined and enforced to ensure all personnel who are provided access to patient data must comply with

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

published procedures to protect the privacy and confidentiality of such information as required by VA.

- Contractor must adhere to the following:
 - a. The use of “thumb drives” or any other medium for transport of information is expressly prohibited.
 - b. Controlled access to system and security software and documentation.
 - c. Recording, monitoring, and control of passwords and privileges.
 - d. All terminated personnel are denied physical and electronic access to all data, program listings, data processing equipment and systems.
 - e. VA, as well as any Contractor (or Subcontractor) systems used to support development, provide the capability to cancel immediately all access privileges and authorizations upon employee termination.
 - f. Contractor PM and VA PM are informed within twenty-four (24) hours of any employee termination.
 - g. Acquisition sensitive information shall be marked "Acquisition Sensitive" and shall be handled as "For Official Use Only (FOUO)".
 - h. Contractor does not require access to classified data.
- Regulatory standard of conduct governs all personnel directly and indirectly involved in procurements. All personnel engaged in procurement and related activities shall conduct business in a manner above reproach and, except as authorized by statute or regulation, with complete impartiality and with preferential treatment for none. The general rule is to strictly avoid any conflict of interest or even the appearance of a conflict of interest in VA/Contractor relationships.
- VA Form 0752 shall be completed by all Contractor employees working on this contract and shall be provided to the CO before any work is performed. In the case that Contractor personnel are replaced in the future, their replacements shall complete VA Form 0752 prior to beginning work.

A6.0 Information Technology Using Sustainable Products

The Contractor shall comply with Sections 524 and Sections 525 of the Energy Independence and Security Act of 2007; Section 104 of the Energy Policy Act of 2005; Executive Order 14148, “Initial Rescissions of Harmful Executive Orders and Actions,” dated January 20, 2025; Executive Order 13221, “Energy-Efficient Standby Power Devices,” dated August 2, 2001; and the Revolutionary Federal Acquisition Regulation (FAR) Overhaul (RFO) to provide ENERGY STAR® certified and Federal Energy Management Program (FEMP) Designated Low Standby Power information technology products, see <https://www.energy.gov/femp/search-energy-efficient-products>. See <http://www.energystar.gov> for complete product specifications and updated lists of Energy Star certified products. FEMP low standby power product listing can be found at <https://www.energy.gov/femp/low-standby-power-product-list>.

The Contractor shall provide products that meet the definition of sustainable products if the products are delivered to the Government; furnished by the Contractor for use by

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

the Government, incorporated into the construction of a public building or public work, or acquired by the Contractor for use in performing services under a Government contract where the cost of the products is a direct cost to a Government contract (versus costs which are normally applied to a contractor's general and administrative expenses or indirect costs).

Specifically, the Contractor shall provide sustainable products under this contract in accordance with FAR 52.223-23 (NOV 2025). The applicable products with their associated certification, designation, and/or ecolabel (e.g. Energy Star, FEMP, Low Standby Power) are identified within the product specifications in this PWS. The Contractor shall self-certify that its proposed products meet the certification(s) / designation(s) specified.

DRAFT

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

**ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/
PRIVACY LANGUAGE**

NOTE: In the event of a conflict, VAAR Security Clauses take precedence over the language in this Addendum B.

**APPLICABLE SECTIONS TAILORED FROM: VA NOTICE 24-12, APRIL 22, 2024,
UPDATE TO VA HANDBOOK 6500.6, CONTRACT SECURITY, APPENDIX C VA
INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE,
FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE**

B1. GENERAL

This entire section applies to all acquisitions requiring any Information Security and Privacy language. Contractors, contractor personnel, Subcontractors and subcontractor personnel shall be subject to the same federal laws, regulations, standards, VA directives and handbooks, as VA personnel regarding information and information system security and privacy.

B2. VA INFORMATION CUSTODIAL LANGUAGE

- The Government shall receive unlimited rights to data/intellectual property first produced and delivered in the performance of this contract or order (hereinafter “contract”) unless expressly stated otherwise in this contract. This includes all rights to source code and all documentation created in support thereof. The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General.
- Information made available to the Contractor by VA for the performance or administration of this contract shall be used only for the purposes specified in the service agreement, SOW, PWS, PD, and/or contract. The Contractor shall not use VA information in any other manner without prior written approval from a VA CO. The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General.
- VA information shall not be co-mingled with any other data on the Contractor’s information systems or media storage systems. The Contractor shall ensure compliance with Federal and VA requirements related to data protection, data encryption, physical data segregation, logical data segregation, classification requirements and media sanitization.
- VA reserves the right to conduct scheduled or unscheduled audits, assessments, or investigations of Contractor Information Technology (IT) resources to ensure information security is compliant with Federal and VA requirements. The Contractor shall provide all necessary access to records (including electronic and

Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946

documentary materials related to the contracts and subcontracts) and support (including access to Contractor and Subcontractor staff associated with the contract) to VA, VA's Office Inspector General (OIG), and/or GAO staff during periodic control assessments, audits, or investigations.

- The Contractor may only use VA information within the terms of the contract and applicable Federal law, regulations, and VA policies. If new Federal information security laws, regulations or VA policies become applicable after execution of the contract, the parties agree to negotiate contract modification and adjustment necessary to implement the new laws, regulations, and/or policies.
- The Contractor shall not make copies of VA information except as specifically authorized and necessary to perform the terms of the contract. If copies are made for restoration purposes, after the restoration is complete, the copies shall be destroyed in accordance with VA Directive 6500, VA Cybersecurity Program and VA Information Security Knowledge Service.
- If a Veterans Health Administration (VHA) contract is terminated for default or cause with a business associate, the related local Business Associate Agreement (BAA) shall also be terminated and actions taken in accordance with VHA Directive 1605.05, Business Associate Agreements. If there is an executed national BAA associated with the contract, VA shall determine what actions are appropriate and notify the contractor.
- The Contractor shall store and transmit VA sensitive information in an encrypted form, using VA-approved encryption tools which are, at a minimum, Federal Information Processing Standards (FIPS) 140-2, Security Requirements for Cryptographic Modules (or its successor) validated and in conformance with VA Information Security Knowledge Service requirements. The Contractor shall transmit VA sensitive information using VA approved Transport Layer Security (TLS) configured with FIPS based cipher suites in conformance with National Institute of Standards and Technology (NIST) 800-52, Guidelines for the Selection, Configuration and Use of Transport Layer Security (TLS) Implementations.
- The Contractor's firewall and web services security controls, as applicable, shall meet or exceed VA's minimum requirements.
- Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the Contractor may use and disclose VA information only in two situations: (i) in response to a qualifying order of a court of competent jurisdiction after notification to VA CO (ii) with written approval from the VA CO. The Contractor shall refer all requests for, demands for production of or inquiries about, VA information and information systems to the VA CO for response.

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

- Notwithstanding the provision above, the Contractor shall not release VA records protected by Title 38 U.S.C. § 5705, Confidentiality of medical quality-assurance records and/or Title 38 U.S.C. § 7332, Confidentiality of certain medical records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse or infection with Human Immunodeficiency Virus (HIV). If the Contractor is in receipt of a court order or other requests for the above-mentioned information, the Contractor shall immediately refer such court order or other requests to the VA CO for response.
- Information made available to the Contractor by VA for the performance or administration of this contract or information developed by the Contractor in performance or administration of the contract shall be protected and secured in accordance with VA Directive 6500 and Identity and Access Management (IAM) Security processes specified in the VA Information Security Knowledge Service.
- Any data destruction done on behalf of VA by a Contractor shall be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, Records and Information Management, VA Handbook 6300.1, Records Management Procedures, and applicable VA Records Control Schedules.
- The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Directive 6500 and NIST 800-88, Guidelines for Media Sanitization prior to termination or completion of this contract. If directed by the COR/CO, the Contractor shall return all Federal Records to VA for disposition.
- Any media, such as paper, magnetic tape, magnetic disks, solid state devices or optical discs that are used to store, process, or access VA information that cannot be destroyed shall be returned to VA. The Contractor shall hold the appropriate material until otherwise directed by the Contracting Officer's Representative (COR) or CO. Items shall be returned securely via VA-approved methods. VA sensitive information must be transmitted utilizing VA-approved encryption tools which are validated under FIPS 140-2 (or its successor) and NIST 800-52. If mailed, the Contractor shall send via a trackable method (USPS, UPS, FedEx, etc.) and immediately provide the COR/CO with the tracking information. Self-certification by the Contractor that the data destruction requirements above have been met shall be sent to the COR/CO within 30 business days of termination of the contract.
- All electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) used to store, process or access VA information shall not be returned to the Contractor at the end of lease, loan, or trade-in. Exceptions to this paragraph shall only be granted with the written approval of VA CO.

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

B3. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

- A Contractor/Subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees and subcontractors only to the extent necessary to perform the services specified in the solicitation or contract. This includes indirect entities, both affiliate of Contractor/Subcontractor and agent of Contractor/Subcontractor.
- Contractors and subcontractors shall sign the VA Information Security Rule of Behavior (ROB) before access is provided to VA information and information systems (see Section 4, Training, below). The ROB contains the minimum user compliance requirements and does not supersede any policies of VA facilities or other agency components which provide higher levels of protection to VA's information or information systems. Users who require privileged access shall complete the VA elevated privilege access request processes before privileged access is granted.
- All Contractors and Subcontractors working with VA information are subject to the same security investigative and clearance requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for contractors shall be in accordance with VA Directive and Handbook 0710, Personnel Vetting Program. The Office of Human Resources and Administration/Operations, Security and Preparedness (HRA/OSP) is responsible for these policies and procedures. Contract personnel who require access to classified information or information systems shall have an appropriate security clearance. Verification of a Security Clearance shall be processed through the Special Security Officer located in HRA/OSP. Contractors shall conform to all requirements stated in the National Industrial Security Program Operating Manual (NISPOM).
- All Contractors and subcontractors shall comply with conditions specified in VAAR 852.204-71(d); Contractor operations required to be in United States. All Contractors and Subcontractors working with VA information must be permanently located within a jurisdiction subject to the law of the United States or its Territories to the maximum extent feasible. If services are proposed to be performed abroad the Contractor must state where all non-U.S. services are provided. The Contractor shall deliver to VA a detailed plan specifically addressing communications, personnel control, data protection and potential legal issues. The plan shall be approved by the COR/CO in writing prior to access being granted.
- The Contractor shall notify the COR/CO in writing immediately (no later than 24 hours) after personnel separation or occurrence of other causes. Causes may include the following:

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

- (1) Contractor/Subcontractor personnel no longer has a need for access to VA information or VA information systems.
 - (2) Contractor/Subcontractor personnel are terminated, suspended, or otherwise has their work on a VA project discontinued for any reason.
 - (3) Contractor believes their own personnel or Subcontractor personnel may pose a threat to their company's working environment or to any company-owned property. This includes Contractor-owned assets, buildings, confidential data, customers, employees, networks, systems, trade secrets and/or VA data.
 - (4) Any previously undisclosed changes to Contractor/Subcontractor background history are brought to light, including but not limited to changes to background investigation or employee record.
 - (5) Contractor/Subcontractor personnel have their authorization to work in the United States revoked.
 - (6) Agreement by which Contractor provides products and services to VA has either been fulfilled or terminated, such that VA can cut off electronic and/or physical access for Contractor personnel.
- In such cases of contract fulfillment, termination, or other causes; the Contractor shall take the necessary measures to immediately revoke access to VA network, property, information, and information systems (logical and physical) by Contractor/Subcontractor personnel. These measures include (but are not limited to): removing and then securing Personal Identity Verification (PIV) badges and PIV – Interoperable (PIV-I) access badges, VA-issued photo badges, credentials for VA facilities and devices, VA-issued laptops, and authentication tokens. Contractors shall notify the appropriate VA COR/CO immediately to initiate access removal.
 - Contractors/Subcontractors who no longer require VA accesses shall return VA-issued property to VA. This property includes (but is not limited to): documents, electronic equipment, keys, and parking passes. PIV and PIV-I access badges shall be returned to the nearest VA PIV Badge Issuance Office. Once they have had access to VA information, information systems, networks and VA property in their possessions removed, Contractors shall notify the appropriate VA COR/CO.

B4. TRAINING

- All contractors and subcontractors requiring access to VA information and VA information systems shall successfully complete the following before being granted access to VA information and its systems:

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

- (1) VA Privacy and Information Security Awareness and Rules of Behavior course (Talent Management System (TMS) #10176) initially and annually thereafter.
 - (2) Sign and acknowledge (electronically through TMS #10176) understanding of and responsibilities for compliance with the Organizational Rules of Behavior, relating to access to VA information and information systems initially and annually thereafter; and
 - (3) Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system or information access [to be defined by the VA program official and provided to the VA CO for inclusion in the solicitation document – i.e., any role-based information security training].
- The Contractor shall provide to the COR/CO a copy of the training certificates and certification of signing the Organizational Rules of Behavior for each applicable employee within five (5) days of the initiation of the contract and annually thereafter, as required.
 - Failure to complete the mandatory annual training is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the required training is complete.

B5. SECURITY INCIDENT INVESTIGATION

- The Contractor, Subcontractor, their employees, or business associates shall immediately (within one hour) report suspected security / privacy incidents to the VA OIT's Enterprise Service Desk (ESD) by calling (855) 673-4357 (TTY: 711). The ESD is OIT's 24/7/365 single point of contact for IT-related issues. After reporting to the ESD, the Contractor, Subcontractor, their employees, or business associates shall, within one hour, provide the COR/CO the incident number received from the ESD.
- To the extent known by the Contractor/Subcontractor, the Contractor/Subcontractor's notice to VA shall identify the information involved and the circumstances surrounding the incident, including the following:
 - (1) The date and time (or approximation of) the Security Incident occurred.
 - (2) The names of individuals involved (when applicable).
 - (3) The physical and logical (if applicable) location of the incident.

Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946

- (4) Why the Security Incident took place (i.e., catalyst for the failure).
- (5) The amount of data belonging to VA believed to have been compromised.
- (6) The remediation measures the Contractor is taking to ensure no future incidents of a similar nature.
- After the Contractor has provided the initial detailed incident summary to VA, they shall continue to provide written updates on any new and relevant circumstances or facts they discover. The Contractor, Subcontractor, and their employees shall fully cooperate with VA or third-party entity performing an independent risk analysis on behalf of VA. Failure to cooperate may be deemed a material breach and grounds for contract termination.
- VA IT Contractors shall follow VA Handbook 6500, Risk Management Framework for VA Information Systems VA Information Security Program, and VA Information Security Knowledge Service guidance for implementing an Incident Response Plan or integrating with an existing VA implementation.
- In instances of theft or break-in or other criminal activity, the Contractor/Subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG, and the VA Office of Security and Law Enforcement. The Contractor, its employees, and its Subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/Subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.
- The Contractor shall comply with VA Handbook 6500.2, Management of Breaches Involving Sensitive Personal Information, which establishes the breach management policies and assigns responsibilities for the oversight, management and reporting procedures associated with managing of breaches.
- With respect to unsecured Protected Health Information (PHI), the Contractor is deemed to have discovered a data breach when the Contractor knew or should have known of breach of such information. When a business associate is part of VHA contract, notification to the covered entity (VHA) shall be made in accordance with the executed BAA.
- If the Contractor or any of its agents fails to protect VA sensitive personal information or otherwise engages in conduct which results in a data breach involving any VA sensitive personal information the Contractor/Subcontractor

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

processes or maintains under the contract; the Contractor shall pay liquidated damages to the VA as set forth in clause [852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs](#).

B6. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

- Information systems designed or developed on behalf of VA at non-VA facilities shall comply with all applicable Federal law, regulations, and VA policies. This includes standards for the protection of electronic Protected Health Information (PHI), outlined in 45 C.F.R. Part 164, Subpart C and information and system security categorization level designations in accordance with FIPS 199, Standards for Security Categorization of Federal Information and Information Systems and FIPS 200, Minimum Security Requirements for Federal Information Systems. Baseline security controls shall be implemented commensurate with the FIPS 199 system security categorization (reference VA Handbook 6500 and VA Trusted Internet Connections (TIC) Architecture).
- Contracted new developments require creation, testing, evaluation, and authorization in compliance with VA Assessment and Authorization (A&A) processes in VA Handbook 6500 and VA Information Security Knowledge Service to obtain an Authority to Operate (ATO). VA Directive 6517, Risk Management Framework for Cloud Computing Services, provides the security and privacy requirements for cloud environments.
- VA IT Contractors, Subcontractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500, VA Handbook 6517, Risk Management Framework for Cloud Computing Services and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO to identify the VA organization responsible for governance or resolution. Contractors shall comply with FAR 39.1, specifically the prohibitions referenced.
- The Contractor (including producers and resellers) shall comply with Office of Management and Budget (OMB) M-26-05 when using third-party software on VA information systems or otherwise affecting the VA information. This includes new software purchases and software renewals for software developed or modified by major version change. The term “software” includes firmware, operating systems, applications and application services (e.g., cloud-based software), as well as products containing software. The Contractor shall provide a self-attestation that secure software development practices are utilized as outlined by Executive Order (EO) 14028 and NIST Guidance. A third-party assessment provided by either a certified Federal Risk and Authorization Management Program (FedRAMP) Third Party Assessor Organization (3PAO) or one

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

approved by the agency shall be acceptable in lieu of a software producer's self-attestation.

- The Contractor shall ensure all delivered applications, systems and information systems are compliant with Homeland Security Presidential Directive (HSPD) 12 and VA Identity and Access management (IAM) enterprise identity management requirements as set forth in OMB M-19-17, M-05-24, FIPS 201-3, Personal Identity Verification (PIV) of Federal Employees and Contractors (or its successor), M-21-31 and supporting NIST guidance. This applies to Commercial Off-The-Shelf (COTS) product(s) that the Contractor did not develop, all software configurations and all customizations.
- The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with VA Handbook 6500, VA Information Security Knowledge Service, IAM enterprise requirements and NIST 800-63, Digital Identity Guidelines, for direct, assertion-based authentication and/or trust-based authentication, as determined by the design and integration patterns. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV and/or Common Access Card (CAC), as determined by the business need and compliance with VA Information Security Knowledge Service specifications.
- The Contractor shall use VA authorized technical security baseline configurations and certify to the COR that applications are fully functional and operate correctly as intended on systems in compliance with VA baselines prior to acceptance or connection into an authorized VA computing environment. If the Defense Information Systems Agency (DISA) has created a Security Technical Implementation Guide (STIG) for the technology, the Contractor may configure to comply with that STIG. If VA determines a new or updated VA configuration baseline needs to be created, the Contractor shall provide required technical support to develop the configuration settings. FAR 39.1 requires the population of operating systems and applications includes all listed on the NIST National Checklist Program Checklist Repository,
- The standard installation, operation, maintenance, updating and patching of software shall not alter the configuration settings from VA approved baseline configuration. Software developed for VA must be compatible with VA enterprise installer services and install to the default "program files" directory with silently install and uninstall. The Contractor shall perform testing of all updates and patching prior to implementation on VA systems.
- Applications designed for normal end users shall run in the standard user context without elevated system administration privileges.

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

- The Contractor-delivered solutions shall reside on VA approved operating systems. Exceptions to this shall only be granted with the written approval of the COR/CO.
- The Contractor shall design, develop, and implement security and privacy controls in accordance with the provisions of VA security system development life cycle outlined in NIST 800-37, Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy, VA Directive and Handbook 6500, and VA Handbook 6517.
- The Contractor shall comply with the Privacy Act of 1974 (the Act), FAR 52.224-2 Privacy Act, and VA rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish a VA function.
- The Contractor shall ensure the security of all procured or developed information systems, systems, major applications, minor applications, enclaves and platform information technologies, including their subcomponents (hereinafter referred to as "Information Systems") throughout the life of this contract and any extension, warranty, or maintenance periods. This includes security configurations, workarounds, patches, hotfixes, upgrades, replacements and any physical components which may be necessary to remediate all security vulnerabilities published or known to the Contractor anywhere in the information systems (including systems, operating systems, products, hardware, software, applications and firmware). The Contractor shall ensure security fixes do not negatively impact the Information Systems.
- When the Contractor is responsible for operations or maintenance of the systems, the Contractor shall apply the security fixes within the timeframe specified by the associated controls on the VA Information Security Knowledge Service. When security fixes involve installing third party patches (such as Microsoft OS patches or Adobe Acrobat), the Contractor shall provide written notice to the VA COR/CO that the patch has been validated as to not affecting the Systems within 10 business days.

B7. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE OR USE

- The Contractor shall comply with all Federal laws, regulations, and VA policies for Information systems (cloud and non-cloud) that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities. Security controls for collecting, processing, transmitting, and storing of VA sensitive information, must be in place. The controls shall be tested by VA or a VA sanctioned 3PAO and approved by VA prior to hosting, operation, maintenance or use of the information system or systems by or on behalf of VA. This includes conducting compliance risk assessments, security architecture analysis, routine vulnerability

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

scanning, system patching, change management procedures and the completion of an acceptable contingency plan for each system. The Contractor's security control procedures shall be the same as procedures used to secure VA-operated information systems.

- Outsourcing (Contractor facility, equipment, or staff) of systems or network operations, telecommunications services or other managed services require Assessment and Authorization (A&A) of the Contractor's systems in accordance with VA Handbook 6500 as specified in VA Information Security Knowledge Service. Major changes to the A&A package may require reviewing and updating all the documentation associated with the change. The Contractor's cloud computing systems shall comply with FedRAMP and VA Directive 6517 requirements.
- The Contractor shall return all electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) on non-VA leased or non-VA owned IT equipment used to store, process or access VA information to VA in accordance with A&A package requirements. This applies when the contract is terminated or completed and prior to disposal of media. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Information Security Knowledge Service requirements and NIST 800-88. The Contractor shall send a self-certification that the data destruction requirements above have been met to the COR/CO within 30 business days of termination of the contract.
- All external internet connections to VA network involving VA information must be in accordance with VA Trusted Internet Connection (TIC) Reference Architecture and VA Directive and Handbook 6513, Secure External Connections and reviewed and approved by VA prior to implementation. Government-owned Contractor-operated systems, third party or business partner networks require a Memorandum of Understanding (MOU) and Interconnection Security Agreements (ISA).
- Contractor procedures shall be subject to periodic, announced, or unannounced assessments by VA officials, the OIG or a 3PAO. The physical security aspects associated with Contractor activities are also subject to such assessments. The Contractor shall report, in writing, any deficiencies noted during the above assessment to the VA COR/CO. The Contractor shall use VA's defined processes to document planned remedial actions that address identified deficiencies in information security policies, procedures, and practices. The Contractor shall correct security deficiencies within the timeframes specified in the VA Information Security Knowledge Service.
- All major information system changes which occur in the production environment shall be reviewed by the VA to determine the impact on privacy and security of the system. Based on the review results, updates to the Authority to Operate

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

(ATO) documentation and parameters may be required to remain in compliance with VA Handbook 6500 and VA Information Security Knowledge Service requirements.

- The Contractor shall conduct an annual privacy and security self-assessment on all information systems and outsourced services as required. Copies of the assessment shall be provided to the COR/CO. The VA/Government reserves the right to conduct assessment using government personnel or a third party if deemed necessary. The Contractor shall correct or mitigate any weaknesses discovered during the assessment.
- VA prohibits the installation and use of personally owned or Contractor-owned equipment or software on VA information systems. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, PWS, PD or contract. All security controls required for government furnished equipment must be utilized in VA approved Other Equipment (OE). Configuration changes to the Contractor OE, must be funded by the owner of the equipment. All remote systems must use a VA-approved antivirus software and a personal (host-based or enclave based) firewall with a VA-approved configuration. The Contractor shall ensure software on OE is kept current with all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-virus software and the firewall on the non-VA owned OE. Approved Contractor OE shall be subject to technical inspection at any time.
- The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems. The system or effected component(s) need(s) to be isolated from the network. A forensic analysis needs to be conducted jointly with VA. Such issues shall be remediated as quickly as practicable, but in no event longer than the timeframe specified by VA Information Security Knowledge Service. If sensitive personal information is compromised reference VA Handbook 6500.2 and Section 5, Security Incident Investigation.
- For cases wherein the Contractor discovers material defects or vulnerabilities impacting products and services they provide to VA, the Contractor shall develop and implement policies and procedures for disclosure to VA, as well as remediation. The Contractor shall, within 30 business days of discovery, document a summary of these vulnerabilities or defects. The documentation shall include a description of the potential impact of each vulnerability and material defect, compensating security controls, mitigations, recommended corrective actions, root cause analysis and/or workarounds (i.e., monitoring). Should there exist any backdoors in the products or services they provide to VA (referring to methods for bypassing computer authentication), the Contractor

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

shall provide the VA CO/CO written assurance they have permanently remediated these backdoors.

- All other vulnerabilities, including those discovered through routine scans or other assessments, shall be remediated based on risk, in accordance with the remediation timelines specified by the VA Information Security Knowledge Service and/or the applicable timeframe mandated by Cybersecurity & Infrastructure Security Agency (CISA) Binding Operational Directive (BOD) 22-01 and BOD 19-02 for Internet-accessible systems. Exceptions to this paragraph shall only be granted with the approval of the COR/CO.

**B8. SECURITY AND PRIVACY CONTROLS COMPLIANCE TESTING,
ASSESSMENT AND AUDITING**

- Should VA request it, the Contractor shall provide a copy of their (corporation's, sole proprietorship's, partnership's, limited liability company (LLC), or other business structure entity's) policies, procedures, evidence and independent report summaries related to specified cybersecurity frameworks (International Organization for Standardization (ISO), NIST Cybersecurity Framework (CSF), etc.). VA or its third-party/partner designee (if applicable) are further entitled to perform their own audits and security/penetration tests of the Contractor's IT or systems and controls, to ascertain whether the Contractor is complying with the information security, network or system requirements mandated in the agreement between VA and the Contractor.
- Any audits or tests of the Contractor or third-party designees/partner VA elects to carry out shall commence within 30 business days of VA notification. Such audits, tests and assessments may include the following: (a): security/penetration tests which both sides agree shall not unduly impact Contractor operations; (b): interviews with pertinent stakeholders and practitioners; (c): document review; and (d): technical inspections of networks and systems the Contractor uses to destroy, maintain, receive, retain, or use VA information.
- As part of these audits, tests and assessments, the Contractor shall provide all information requested by VA. This information includes, but is not limited to, the following: equipment lists, network or infrastructure diagrams, relevant policy documents, system logs or details on information systems accessing, transporting, or processing VA data.
- The Contractor and at its own expense, shall comply with any recommendations resulting from VA audits, inspections and tests. VA further retains the right to view any related security reports the Contractor has generated as part of its own security assessment. The Contractor shall also notify VA of the existence of any such security reports or other related assessments, upon completion and validation.

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

- VA appointed auditors or other government agency partners may be granted access to such documentation on a need-to-know basis and coordinated through the COR/CO. The Contractor shall comply with recommendations which result from these regulatory assessments on the part of VA regulators and associated government agency partners.

B9. PRODUCT INTEGRITY, AUTHENTICITY, PROVENANCE, ANTI-COUNTERFEIT AND ANTI-TAMPERING

- The Contractor shall comply with Code of Federal Regulations (CFR) Title 15 Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain", which prohibits ICTS Transactions from foreign adversaries. ICTS Transactions are defined as any acquisition, importation, transfer, installation, dealing in or use of any information and communications technology or service, including ongoing activities, such as managed services, data transmission, software updates, repairs or the platforming or data hosting of applications for consumer download.
- When contracting terms require the Contractor to procure equipment, the Contractor shall purchase or acquire the equipment from an Original Equipment Manufacturer (OEM) or an authorized reseller of the OEM. The Contractor shall attest that equipment procured from an OEM or authorized reseller or distributor is authentic. If procurement is unavailable from an OEM or authorized reseller, the Contractor shall submit in writing, details of the circumstances prohibiting this from happening and procure a product waiver from the VA COR/CO.
- All Contractors shall establish, implement, and provide documentation for risk management practices for supply chain delivery of hardware, software (to include patches) and firmware provided under this agreement. Documentation shall include chain of custody practices, inventory management program, information protection practices, integrity management program for sub-supplier provided components, and replacement parts requests. The Contractor shall make spare parts available. All Contractor(s) shall specify how digital delivery for procured products, including patches, shall be validated and monitored to ensure consistent delivery. The Contractor shall apply encryption technology to protect procured products throughout the delivery process.
- If a Contractor provides software or patches to VA, the Contractor shall publish or provide a hash conforming to the FIPS Security Requirements for Cryptographic Modules (FIPS 140-2 or successor).
- The Contractor shall provide a software bill of materials (SBOM) for procured (to include licensed products) and consist of a list of components and associated metadata which make up the product. SBOMs must be generated in one of the

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

data formats defined in the National Telecommunications and Information Administration (NTIA) report “The Minimum Elements for a Software Bill of Materials (SBOM).”

- Contractors shall use or arrange for the use of trusted channels to ship procured products, such as U.S. registered mail and/or tamper-evident packaging for physical deliveries.
- Throughout the delivery process, the Contractor shall demonstrate a capability for detecting unauthorized access (tampering).
- The Contractor shall demonstrate chain-of-custody documentation for procured products and require tamper-evident packaging for the delivery of this hardware.

B10. VIRUSES, FIRMWARE, AND MALWARE

- The Contractor shall execute due diligence to ensure all provided software and patches, including third-party patches, are free of viruses and/or malware before releasing them to or installing them on VA information systems.
- The Contractor warrants it has no knowledge of and did not insert, any malicious virus and/or malware code into any software or patches provided to VA which could potentially harm or disrupt VA information systems. The Contractor shall use due diligence, if supplying third-party software or patches, to ensure the third-party has not inserted any malicious code and/or virus which could damage or disrupt VA information systems.
- The Contractor shall provide or arrange for the provision of technical justification as to why any “false positive” hit has taken place to ensure their code’s supply chain has not been compromised. Justification may be required, but is not limited to, when install files, scripts, firmware, or other Contractor-delivered software solutions (including third-party install files, scripts, firmware, or other software) are flagged as malicious, infected, or suspicious by an anti-virus vendor.
- The Contractor shall not upload (intentionally or negligently) any virus, worm, malware or any harmful or malicious content, component and/or corrupted data/source code (hereinafter “virus or other malware”) onto VA computer and information systems and/or networks. If introduced (and this clause is violated), upon written request from the VA CO, the Contractor shall:
 - (1) Take all necessary action to correct the incident, to include any and all assistance to VA to eliminate the virus or other malware throughout VA’s information networks, computer systems and information systems; and

Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946

- (2) Use commercially reasonable efforts to restore operational efficiency and remediate damages due to data loss or data integrity damage, if the virus or other malware causes a loss of operational efficiency, data loss, or damage to data integrity.

B11. CRYPTOGRAPHIC REQUIREMENT

- The Contractor shall document how the cryptographic system supporting the Contractor's products and/or services protect the confidentiality, data integrity, authentication and non-repudiation of devices and data flows in the underlying system.
- The Contractor shall use only approved cryptographic methods as defined in FIPS 140-2 (or its successor) and NIST 800-52 standards when enabling encryption on its products.
- The Contractor shall provide or arrange for the provision of an automated remote key-establishment method which protects the confidentiality and integrity of the cryptographic keys.
- The Contractor shall ensure emergency re-keying of all devices can be remotely performed within 30 business days.
- The Contractor shall provide or arrange for the provision of a method for updating cryptographic primitives or algorithms.

B12. PATCHING GOVERNANCE

- The Contractor shall provide documentation detailing the patch management, vulnerability management, mitigation and update processes (to include third-party) prior to the connection of electronic devices, assets or equipment to VA's assets. This documentation shall include information regarding the following:
 - (1) The resources and technical capabilities to sustain the program or process (e.g., how the integrity of a patch is validated by VA); and.
 - (2) The approach and capability to remediate newly reported zero-day vulnerabilities for Contractor products.
- The Contractor shall verify and provide documentation all procured products (including third-party applications, hardware, software, operating systems, and firmware) have appropriate updates and patches installed prior to delivery to VA.
- The Contractor shall provide or arrange the provision of appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

for their products and services within 30 days of discovery. Updates to remediate critical or emergent vulnerabilities shall be provided within seven business days of discovery. If updates cannot be made available by Contractor within these time periods, the Contractor shall submit mitigations, methods of exploit detection and/or workarounds to the COR/CO prior to the above deadlines.

- The Contractor shall provide or arrange for the provision of appropriate hardware, software and/or firmware updates, when those products, including open-source software, are provided to the VA, to remediate newly discovered vulnerabilities or weaknesses. Remediations of products or services provided to the VA's system environment must be provided within 30 business days of availability from the original supplier and/or patching source. Updates to remediate critical vulnerabilities applicable to the Contractor's use of the third-party product in its system environment shall be provided within seven business days of availability from the original supplier and/or patching source. If applicable third-party updates cannot be integrated, tested and made available by Contractor within these time periods, mitigations and/or workarounds shall be provided to the COR/CO before the above deadlines.

B13. SPECIALIZED DEVICES/SYSTEMS (MEDICAL DEVICES, SPECIAL PURPOSE SYSTEMS, RESEARCH SCIENTIFIC COMPUTING)

- Contractor supplies/delivered Medical Devices, Special Purpose Systems-Operational Technology (SPS-OT) and Research Scientific Computing Devices shall comply with all applicable Federal law, regulations, and VA policies. New developments require creation, testing, evaluation, and authorization in compliance with processes specified on the Specialized Device Cybersecurity Department Enterprise Risk Management (SDCD-ERM) Portal, VA Directive 6550, Pre-Procurement Assessment and Implementation of Medical Devices/Systems, VA Handbook 6500, and the VA Information Security Knowledge Service. Deviations from Federal law, regulations, and VA Policy are identified and documented as part of VA Directive 6550 and/or the VA Enterprise Risk Analysis (ERA) processes for Specialized Devices/Systems processes.
- All Contractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500 and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO for governance or resolution.
- The Contractor shall certify to the COR/CO that devices/systems that have completed the VA Enterprise Risk Analysis (ERA) process for Specialized Devices/Systems are fully functional and operate correctly as intended.

Supply Chain Development Security Operations (SCDSO) Integration VA-26-00021946

Devices/systems must follow the VA ERA authorized configuration prior to acquisition and connection to the VA computing environment. If VA determines a new VA ERA needs to be created, the Contractor shall provide required technical support to develop the configuration settings. Major changes to a previously approved device/system shall require a new ERA.

- The Contractor shall comply with all practices documented by the Food Drug and Administration (FDA) Premarket Submission for Management of Cybersecurity in Medical Devices and Postmarket Management of Cybersecurity in Medical Devices.
- The Contractor shall design devices capable of accepting all applicable security patches with or without the support of the Contractor personnel. If patching can only be completed by the Contractor, the Contractor shall commit the resources needed to patch all applicable devices at all VA locations. If unique patching instructions or packaging is needed, the Contractor shall provide the necessary information in conjunction with the validation/testing of the patch. The Contractor shall apply security patches within 30 business days of the patch release and have a formal tracking process for any security patches not implemented to include explanation when a device cannot be patched.
- The Contractor shall provide devices able to install and maintain VA-approved antivirus capabilities with the capability to quarantine files and be updated as needed in response to incidents. Alternatively, a VA-approved whitelisting application may be used when the Contractor cannot install an anti-virus / anti-malware application.
- The Contractor shall verify and document all software embedded within the device does not contain any known viruses or malware before delivery to or installation at a VA location.
- Devices and other equipment or systems containing media (hard drives, optical disks, solid state, and storage via chips/firmware) with VA sensitive information shall be returned to the Contractor with media removed. When the contract requires return of equipment, the options available to the Contractor are the following:
 - (1) The Contractor shall accept the system without the drive, firmware and solid state.
 - (2) VA's initial device purchase includes a spare drive or other replacement media which must be installed in place of the original drive at time of turn-in; or

**Supply Chain Development Security Operations (SCDSO) Integration
VA-26-00021946**

(3) Due to the highly specialized and sometimes proprietary hardware and software associated with the device, if it is not possible for VA to retain the hard drive, firmware, and solid state, then:

- (a) The equipment Contractor shall have an existing BAA if the device being traded in has sensitive information stored on it and hard drive(s) from the system are being returned physically intact.
- (b) Any fixed hard drive, Complementary Metal-Oxide-Semiconductor (CMOS), Programmable Read-Only Memory (PROM), solid state and firmware on the device must be non-destructively sanitized to the greatest extent possible without negatively impacting system operation. Selective clearing down to patient data folder level is recommended using VA approved and validated overwriting technologies/methods/tools. Applicable media sanitization specifications need to be pre-approved and described in the solicitation, contract, or order.

B14. DATA CENTER PROVISIONS

- The Contractor shall ensure the VA network is accessed in accordance with VA Directive 6500 and IAM security processes specified in the VA Information Security Knowledge Service.
- The Contractor shall ensure network infrastructure and data availability in accordance with VA information system business continuity procedures specified in the VA Information Security Knowledge Service.
- The Contractor shall ensure any connections to the internet or other external networks for information systems occur through managed interfaces utilizing VA approved boundary protection devices (e.g., internet proxies, gateways, routers, firewalls, guards or encrypted tunnels).
- The Contractor shall encrypt all traffic across the segment of the Wide Area Network (WAN) it manages and no unencrypted Out of Band (OOB) Internet Protocol (IP) traffic shall traverse the network.
- The Contractor shall ensure tunnel endpoints are routable addresses at each VA operating site.
- The Contractor shall secure access from Local Area Networks (LANs) at co-located sites in accordance with VA TIC Reference Architecture, VA Directive and Handbook 6513, and MOU/ISA process specified in the VA Information Security Knowledge Service.